

অধ্যায়-১

সাইবার নিরাপত্তা এবং বুঁকি নিয়ন্ত্রণ

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

*** ১। সাইবার নিরাপত্তা (Cyber Security) বলতে কী বুঝায়?

বাকশিবো- ২০১৯, ২১, ২৪'পরি

উত্তর : সাইবার নিরাপত্তা (Cyber Security) হলো এমন একটি প্রক্রিয়া, যার মাধ্যমে কম্পিউটার, সার্ভার, মোবাইল ডিভাইস, ইলেকট্রনিক সিস্টেম, নেটওয়ার্ক এবং ডাটাকে ডিজিটাল আক্রমণ বা হ্যাকিং থেকে রক্ষা করা হয়।

* ২। সাইবার নিরাপত্তা কয় প্রকার ও কী কী?

বাকশিবো- ২০২২

উত্তর : সাইবার নিরাপত্তাকে কাজের ক্ষেত্র এবং সুরক্ষার ধরন অনুযায়ী সাধারণত ৫টি প্রধান ভাগে ভাগ করা যায়। যথাঃ

- i) নেটওয়ার্ক নিরাপত্তা (Network Security)
- ii) অ্যাপ্লিকেশন নিরাপত্তা (Application Security)
- iii) তথ্য বা ডাটা নিরাপত্তা (Information Security - InfoSec)
- iv) ক্লাউড নিরাপত্তা (Cloud Security)
- v) এন্ডপয়েন্ট নিরাপত্তা (Endpoint Security)

***** ৩। সাইবার অপরাধ (Cyber Crime) বলতে কী বুঝ?**

বাকাশিবো- ২০১৯, ২১, ২২

উত্তর : ডিজিটাল প্রযুক্তি বা ইন্টারনেট ব্যবহার করে কোনো ব্যক্তি, প্রতিষ্ঠান বা রাষ্ট্রের ক্ষতি করা, তথ্য চুরি করা, অর্থ আত্মসাৎ করা বা হয়রানি করাই হলো সাইবার অপরাধ।

*** ৪। ভাইরাস (Virus) বলতে কী বুঝ?**

উত্তর : ভাইরাস (Virus) হলো এক ধরনের ম্যালওয়্যার (Malware) বা ক্ষতিকারক সফটওয়্যার, যা কোনো বৈধ প্রোগ্রাম বা ফাইলের সাথে নিজেকে যুক্ত করে এবং ব্যবহারকারীর অজান্তেই কম্পিউটারের ক্ষতি সাধন করে।

***** ৫। ট্রোজান হর্স (Trojan Horse) কী?**

বাকাশিবো- ২০২০, ২১

উত্তর : ট্রোজান হর্স (Trojan Horse) বা সংক্ষেপে ট্রোজান হলো এক ধরনের ম্যালওয়্যার, যা নিজেকে বৈধ বা উপকারী সফটওয়্যার হিসেবে পরিচয় দিয়ে ব্যবহারকারীকে বিভ্রান্ত করে।

নোটঃ নামকরণ করা হয়েছে গ্রিক পুরাণের বিখ্যাত "ট্রয়ের কাঠের ঘোড়া" (Wooden Horse of Troy) এর গল্প থেকে। গল্পে যেমন গ্রিক সৈন্যরা বিশাল কাঠের ঘোড়ার ভেতরে লুকিয়ে ট্রয় নগরীতে প্রবেশ করেছিল, তেমনি এই ম্যালওয়্যারটিও ভালো সফটওয়্যারের আড়ালে লুকিয়ে কম্পিউটারে প্রবেশ করে।

৬। ব্যাকডোর (Backdoor) কী?

উত্তর : ব্যাকডোর হলো এমন একটি গোপন পথ বা পদ্ধতি, যার মাধ্যমে স্বাভাবিক নিরাপত্তা ব্যবস্থা (যেমনঃ ইউজারনেম, পাসওয়ার্ড বা এনক্রিপশন) এড়িয়ে কোনো কম্পিউটার সিস্টেম, নেটওয়ার্ক বা সফটওয়্যারে প্রবেশ করা যায়।

*** ৭। হ্যাকিং (Hacking) কী?

বাকাশিবো- ২০২৪'পরি

উত্তর : হ্যাকিং হলো এমন একটি প্রক্রিয়া, যার মাধ্যমে কোনো কম্পিউটার সিস্টেম, নেটওয়ার্ক বা ডিজিটাল ডিভাইসের নিরাপত্তা ব্যবস্থার দুর্বলতা খুঁজে বের করা হয় এবং সেই দুর্বলতাকে কাজে লাগিয়ে অনুমতি ছাড়াই সেই সিস্টেমে প্রবেশ বা নিয়ন্ত্রণ নেওয়া হয়।

*** ৮। ইথিক্যাল হ্যাকিং (Ethical Hacking) বলতে কী বুঝ?

বাকাশিবো- ২০২৪'পরি

উত্তর : ইথিক্যাল হ্যাকিং হলো এমন একটি বৈধ ও পেশাদার প্রক্রিয়া, যার মাধ্যমে কোনো ব্যক্তি বা প্রতিষ্ঠানের অনুমতি নিয়ে তাদের কম্পিউটার সিস্টেম, নেটওয়ার্ক বা অ্যাপ্লিকেশনের নিরাপত্তার দুর্বলতা খুঁজে বের করা হয়।

৯। দুর্বলতা (Vulnerability) বলতে কী বুঝায়?

উত্তর : সাইবার নিরাপত্তার পরিভাষায় দুর্বলতা হলো কোনো কম্পিউটার সিস্টেম, নেটওয়ার্ক, সফটওয়্যার বা হার্ডওয়্যারের এমন কোনো ত্রুটি বা

সীমাবদ্ধতা, যা ব্যবহার করে হ্যাকাররা সিস্টেমের নিরাপত্তা ভেঙে ফেলতে পারে।

**** ১০। সম্পূর্ণতা (Integrity) বলতে কী বুঝ?**

বাকাশিবো- ২০২৫

উত্তর : Integrity বা অখণ্ডতা বলতে বোঝায়-কোনো তথ্য বা ডেটা ঠিক যেভাবে তৈরি বা পাঠানো হয়েছে, তা অবিকল সেই অবস্থায় রাখা। অনুমোদিত ব্যক্তি ছাড়া অন্য কেউ যেন সেই তথ্য পরিবর্তন, পরিবর্ধন বা নষ্ট করতে না পারে, তা নিশ্চিত করাই হলো ইন্টিগ্রিটি।

SOS

সংক্ষিপ্ত প্রশ্নোত্তর :

**** ১। সাইবার নিরাপত্তার মূল লক্ষ্যগুলো লেখ।**

উত্তর : সাইবার নিরাপত্তার প্রধান বা মূল লক্ষ্যগুলোকে সংক্ষেপে CIA Triad বলা হয়। এই তিনটি মূল স্তরের ওপর ভিত্তি করেই পুরো নিরাপত্তা ব্যবস্থা গড়ে ওঠে। নিচে সাইবার নিরাপত্তার ৩টি মূল লক্ষ্য বিস্তারিত আলোচনা করা হলো :

i) গোপনীয়তা (Confidentiality) : এর মূল লক্ষ্য হলো, তথ্য যেন শুধুমাত্র অনুমোদিত ব্যক্তিরাই দেখতে বা ব্যবহার করতে পারে। অননুমোদিত কোনো ব্যক্তি, প্রোগ্রাম বা সিস্টেম যেন তথ্যের নাগাল না পায়।

উদাহরণ : আপনার ফেসবুকের মেসেজ যেন আপনি এবং যার সাথে চ্যাট করছেন, তারা ছাড়া অন্য কেউ পড়তে না পারে। পাসওয়ার্ড এবং এনক্রিপশন (Encryption) ব্যবহার করে এটি নিশ্চিত করা হয়।

ii) অখণ্ডতা (Integrity) : তথ্যের সঠিকতা বজায় রাখা এবং কেউ যেন অনুমতি ছাড়া তথ্য পরিবর্তন, পরিবর্ধন বা নষ্ট করতে না পারে, তা নিশ্চিত করা। তথ্যটি উৎস থেকে গন্তব্যে পৌঁছানো পর্যন্ত অবিকল একই থাকবে।

উদাহরণ : আপনি পরীক্ষার রেজাল্ট শিটে যা পেয়েছেন, হ্যাকার যেন তা পরিবর্তন করে নম্বর বাড়িয়ে বা কমিয়ে দিতে না পারে।

iii) প্রাপ্যতা (Availability) : এর অর্থ হলো, যখন তথ্যের প্রয়োজন হবে, তখন যেন অনুমোদিত ব্যবহারকারী তা সহজেই পায়। সার্ভার বা সিস্টেম সবসময় সচল রাখা এর লক্ষ্য।

উদাহরণ : আপনি যখনই মোবাইল ব্যাংকিং অ্যাপে ঢুকবেন, তখনই যেন ব্যালেন্স চেক করতে পারেন। হ্যাকাররা অনেক সময় সার্ভার জ্যাম করে (DDoS Attack) এই প্রাপ্যতা নষ্ট করার চেষ্টা করে।

*** ২। ইথিক্যাল হ্যাকিং কেন প্রয়োজন?

বাকাশিবো-২০২৪'পরি

অথবা, ইথিক্যাল হ্যাকিং এর উদ্দেশ্যাবলি লেখ।

উত্তর : নিচে ইথিক্যাল হ্যাকিং কেন প্রয়োজন, তার প্রধান কারণগুলো আলোচনা করা হলোঃ

i) দুর্বলতা খুঁজে বের করা ও সমাধান : ব্ল্যাক হ্যাট হ্যাকাররা আক্রমণ করার আগেই সিস্টেমের নিরাপত্তা ত্রুটি বা দুর্বলতাগুলো খুঁজে বের করা এবং তা

সমাধান (Patch) করা ইথিক্যাল হ্যাকিংয়ের প্রধান কাজ। এতে সিস্টেম হ্যাক হওয়ার ঝুঁকি কমে যায়।

ii) তথ্য চুরি রোধ : প্রতিষ্ঠান বা গ্রাহকদের সংবেদনশীল তথ্য (যেমনঃ পাসওয়ার্ড, ক্রেডিট কার্ড নম্বর, ব্যক্তিগত ছবি) হ্যাকারদের হাত থেকে রক্ষা করার জন্য ইথিক্যাল হ্যাকিং প্রয়োজন। এটি তথ্যের গোপনীয়তা (Confidentiality) নিশ্চিত করে।

iii) আর্থিক ক্ষতি থেকে রক্ষা : একটি বড় সাইবার আক্রমণ বা র্যানসামওয়্যার অ্যাটাক কোনো কোম্পানিকে আর্থিকভাবে দেউলিয়া করে দিতে পারে। ইথিক্যাল হ্যাকাররা আগে থেকেই নিরাপত্তা নিশ্চিত করে এই বিশাল আর্থিক ক্ষতি থেকে প্রতিষ্ঠানকে বাঁচায়।

iv) জাতীয় নিরাপত্তা রক্ষা : দেশের প্রতিরক্ষা ব্যবস্থা, বিদ্যুৎ কেন্দ্র, ব্যাংকিং সেক্টর এবং সরকারি নথিপত্র এখন ডিজিটাল নেটওয়ার্কের ওপর নির্ভরশীল। বিদেশি হ্যাকার বা সাইবার সন্ত্রাসীদের হাত থেকে দেশের এই গুরুত্বপূর্ণ অবকাঠামো রক্ষা করতে ইথিক্যাল হ্যাকাররা "সাইবার আর্মি" হিসেবে কাজ করে।

v) গ্রাহকের আস্থা অর্জন : যে কোম্পানির নিরাপত্তা ব্যবস্থা যত শক্তিশালী, গ্রাহকরা সেই কোম্পানিকে তত বেশি বিশ্বাস করে। ইথিক্যাল হ্যাকিং নিশ্চিত করে যে ওই প্রতিষ্ঠানের সেবা ব্যবহার করা নিরাপদ।

vi) আইনি সুরক্ষা : অনেক দেশে গ্রাহকের ডেটা সুরক্ষা দেওয়া আইনের বাধ্যতামূলক। ইথিক্যাল হ্যাকিংয়ের মাধ্যমে কোম্পানিগুলো নিশ্চিত হয় যে

তারা সব ধরনের সাইবার আইন মেনে চলছে, ফলে আইনি ঝামেলা এড়ানো যায় ।

***** ৩ । ইথিক্যাল হ্যাকিং এর প্রকারভেদ বর্ণনা কর ।**

বাকাশিবো-২০২৫

উত্তর : একজন ইথিক্যাল হ্যাকারকে সিস্টেম সম্পর্কে কতটুকু তথ্য দেওয়া হয়েছে, তার ওপর ভিত্তি করে হ্যাকিংকে ৩টি বক্সে ভাগ করা হয়ঃ

i) ব্ল্যাক বক্স টেস্টিং (Black Box Testing) : এখানে ইথিক্যাল হ্যাকারকে টার্গেট সিস্টেম সম্পর্কে কোনো তথ্যই দেওয়া হয় না । তাকে একজন অপরিচিত বা বাইরের হ্যাকারের (Attacker) মতো শূন্য থেকে দুর্বলতা খুঁজে বের করতে হয় । এটিই আসল হ্যাকিংয়ের সবচেয়ে কাছাকাছি পদ্ধতি ।

ii) হোয়াইট বক্স টেস্টিং (White Box Testing) : এখানে হ্যাকারকে সিস্টেমের সব তথ্য (সোর্স কোড, নেটওয়ার্ক ম্যাপ, পাসওয়ার্ড) আগেই দিয়ে দেওয়া হয় । হ্যাকারের কাজ হলো কোডের ভেতর লুকিয়ে থাকা গভীর কোনো ত্রুটি খুঁজে বের করা । এটি সাধারণত ডেভেলপার বা কোম্পানির নিজস্ব লোকরা করে থাকে ।

iii) গ্রে বক্স টেস্টিং (Grey Box Testing) : এটি ব্ল্যাক এবং হোয়াইট বক্সের মিশ্রণ । এখানে হ্যাকারকে আংশিক তথ্য (যেমনঃ শুধু সাধারণ ইউজার আইডি বা নেটওয়ার্কের কিছু অংশ) জানানো হয় । বাইরের একজন সাধারণ ইউজার সিস্টেমে ঢুকে কতটা ক্ষতি করতে পারে, তা দেখার জন্য এটি করা হয় ।

**** ৪ । ইথিক্যাল হ্যাকিং এর ধাপগুলো লেখ ।**

উত্তর : ইথিক্যাল হ্যাকিং একটি সুশৃঙ্খল প্রক্রিয়া । একজন ইথিক্যাল হ্যাকার সাধারণত ৫টি (রিপোর্টিং সহ ৬টি) ধাপে এই কাজটি সম্পন্ন করেন । এই ধাপগুলোকে "Phases of Hacking" বলা হয় ।

নিচে ধাপগুলো বিস্তারিত আলোচনা করা হলো :

১. তথ্য সংগ্রহ : এটি হ্যাকিংয়ের প্রথম এবং সবচেয়ে গুরুত্বপূর্ণ ধাপ । এখানে হ্যাকার টার্গেট সিস্টেম বা কোম্পানি সম্পর্কে যথাসম্ভব বেশি তথ্য সংগ্রহ করার চেষ্টা করেন ।
২. স্ক্যানিং : প্রথম ধাপে পাওয়া তথ্যের ওপর ভিত্তি করে হ্যাকার বিভিন্ন টুলস ব্যবহার করে সিস্টেমের নির্দিষ্ট দুর্বলতা বা খোলা পথ (Open Ports) খোঁজার চেষ্টা করেন ।
৩. সিস্টেমে প্রবেশ : এটিই মূল হ্যাকিং ধাপ । স্ক্যানিংয়ের মাধ্যমে পাওয়া দুর্বলতাকে কাজে লাগিয়ে হ্যাকার সিস্টেমে প্রবেশ করেন বা নিয়ন্ত্রণ নেন ।
৪. এক্সেস ধরে রাখা : একবার সিস্টেমে ঢোকার পর, হ্যাকার চেষ্টা করেন ভবিষ্যতে যেন আবার সহজে ঢোকা যায় । কারণ সিস্টেম অ্যাডমিন মূল দুর্বলতাটি ঠিক করে ফেললে হ্যাকার আর ঢুকতে পারবেন না । তাই তিনি বিকল্প পথ তৈরি করেন ।
৫. প্রমাণ বা চিহ্ন মুছে ফেলা : সিস্টেমে ঢোকার পর যেন কেউ তাকে ট্রেস বা শনাক্ত করতে না পারে, সেজন্য হ্যাকার তার উপস্থিতির সব প্রমাণ মুছে ফেলেন ।

৬. রিপোর্টিং : এটিই ইথিক্যাল হ্যাকিং এবং সাধারণ হ্যাকিংয়ের প্রধান পার্থক্য। ওপরের ৫টি ধাপ শেষ করার পর ইথিক্যাল হ্যাকার একটি বিস্তারিত রিপোর্ট তৈরি করেন।

SOS**রচনামূলক প্রশ্নোত্তর :**

**** ১। ব্যবসা প্রতিষ্ঠান ও সমাজে সাইবার নিরাপত্তার গুরুত্ব আলোচনা কর।**

বাকাশিবো-২০২২

উত্তর : বর্তমান ডিজিটাল যুগে ব্যবসা প্রতিষ্ঠান এবং সমাজের প্রতিটি স্তরে সাইবার নিরাপত্তা বা সাইবার সিকিউরিটির গুরুত্ব অপরিসীম। প্রযুক্তি যেমন আমাদের জীবন সহজ করেছে, তেমনি সাইবার অপরাধের ঝুঁকিও বাড়িয়েছে।

নিচে ব্যবসা প্রতিষ্ঠান ও সমাজে সাইবার নিরাপত্তার গুরুত্ব আলাদাভাবে আলোচনা করা হলোঃ

ক. ব্যবসা প্রতিষ্ঠানে সাইবার নিরাপত্তার গুরুত্ব

১. গ্রাহকের তথ্যের সুরক্ষা : ব্যাংক, ই-কমার্স বা যেকোনো সেবামূলক প্রতিষ্ঠানে গ্রাহকদের ব্যক্তিগত তথ্য (নাম, ঠিকানা, ক্রেডিট কার্ড নম্বর) জমা থাকে। সাইবার নিরাপত্তা নিশ্চিত না করলে হ্যাকাররা এই তথ্য চুরি করতে পারে, যা গ্রাহক এবং প্রতিষ্ঠান উভয়ের জন্যই বিপজ্জনক।

২. আর্থিক ক্ষতি রোধ : র্যানসামওয়্যার (Ransomware) আক্রমণ বা আর্থিক জালিয়াতির মাধ্যমে হ্যাকাররা প্রতিষ্ঠানের কোটি কোটি টাকা হাতিয়ে নিতে পারে। সাইবার নিরাপত্তা ব্যবস্থা শক্তিশালী হলে এই বিপুল আর্থিক ক্ষতি থেকে বাঁচা সম্ভব।

৩. সুনাম ও আস্থা রক্ষা : কোনো কোম্পানি হ্যাকিংয়ের শিকার হলে গ্রাহকদের কাছে তাদের বিশ্বাসযোগ্যতা নষ্ট হয়ে যায়। গ্রাহকরা মনে করেন তাদের তথ্য সেখানে নিরাপদ নয়। ব্যবসার সুনাম ধরে রাখতে সাইবার নিরাপত্তা অপরিহার্য।

৪. ব্যবসায়িক গোপনীয়তা রক্ষা : প্রতিটি কোম্পানির নিজস্ব কিছু গোপন কৌশল, ভবিষ্যৎ পরিকল্পনা বা পণ্যের ডিজাইন থাকে (Intellectual Property)। হ্যাকাররা বা প্রতিদ্বন্দ্বী কোম্পানিরা যেন এই তথ্য চুরি করতে না পারে, তার জন্য কঠোর নিরাপত্তা প্রয়োজন।

৫. নিরবচ্ছিন্ন সেবা নিশ্চিত করা : সাইবার আক্রমণ (যেমনঃ DDoS Attack) হলে প্রতিষ্ঠানের ওয়েবসাইট বা সার্ভার ডাউন হয়ে যেতে পারে, ফলে কাজকর্ম বন্ধ হয়ে যায়। সাইবার নিরাপত্তা নিশ্চিত করে যে ব্যবসা সবসময় সচল থাকবে।

খ. সমাজে সাইবার নিরাপত্তার গুরুত্ব :

১. ব্যক্তিগত গোপনীয়তা রক্ষা : সমাজের প্রতিটি মানুষ এখন স্মার্টফোন ও সোশ্যাল মিডিয়া ব্যবহার করে। সাইবার নিরাপত্তা না থাকলে মানুষের ব্যক্তিগত ছবি, চ্যাট বা লোকেশন হ্যাক হতে পারে, যা ব্ল্যাকমেইলিং বা সামাজিক হয়রানির কারণ হতে পারে।

২. অর্থনৈতিক নিরাপত্তা : সাধারণ মানুষ এখন মোবাইল ব্যাংকিং (বিকাশ, নগদ) ও এটিএম ব্যবহার করে। সাইবার নিরাপত্তা ব্যবস্থা শক্তিশালী বলেই মানুষ নিশ্চিন্তে ডিজিটাল লেনদেন করতে পারছে। এর অভাবে মানুষের কষ্টার্জিত টাকা চুরি হওয়ার ঝুঁকি থাকে।

৩. সাইবার বুলিং ও হয়রানি রোধ : সমাজে নারী ও শিশুরা প্রায়ই সাইবার বুলিং বা অনলাইন হয়রানির শিকার হয়। সাইবার নিরাপত্তা আইন এবং সচেতনতা তাদের এই মানসিক নির্যাতন থেকে রক্ষা করতে সাহায্য করে।

৪. জাতীয় ও জরুরি পরিষেবা রক্ষা : বিদ্যুৎ কেন্দ্র, পানি সরবরাহ ব্যবস্থা, ট্রাফিক কন্ট্রোল এবং হাসপাতালের মতো জরুরি সেবাগুলো এখন নেটওয়ার্কের মাধ্যমে নিয়ন্ত্রিত হয়। সাইবার হামলা হলে পুরো সমাজ ব্যবস্থায় বিপর্যয় নেমে আসতে পারে। (যেমনঃ বিদ্যুৎ গ্রিড হ্যাক হলে পুরো দেশ অন্ধকারে ডুবে যাবে)।

৫. গুজব ও ভুয়া তথ্য প্রতিরোধ : সামাজিক যোগাযোগ মাধ্যমে ভুয়া তথ্য ছড়িয়ে দাঙ্গা বা অস্থিরতা সৃষ্টি করা এখন সহজ। সাইবার নিরাপত্তা ব্যবস্থা এবং মনিটরিং-এর মাধ্যমে এই গুজব বা প্রোপাগান্ডা রোধ করে সামাজিক শান্তি বজায় রাখা সম্ভব।

*** ২। সাইবার নিরাপত্তার হুমকিসমূহ বর্ণনা কর। **বাকাশিবো- ২০১৯, ২০**

উত্তর : সাইবার নিরাপত্তার হুমকিসমূহকে (Cyber Security Threats) প্রধানত কয়েকটি ভাগে ভাগ করা যায়। হ্যাকাররা বা সাইবার অপরাধীরা বিভিন্ন কৌশলে সিস্টেমের ক্ষতি করার চেষ্টা করে।

নিচে প্রধান সাইবার হুমকিসমূহ আলোচনা করা হলো :

১. ম্যালওয়্যার (Malware) : ম্যালওয়্যার হলো "Malicious Software"-এর সংক্ষিপ্ত রূপ। এটি এমন সব সফটওয়্যার বা প্রোগ্রাম যা কম্পিউটারের ক্ষতি করে। এর মধ্যে রয়েছে :

i) ভাইরাস (Virus) : যা অন্য ফাইলের সাথে যুক্ত হয়ে ছড়ায়।

ii) ওয়ার্ম (Worm) : এটি ভাইরাসের মতোই, তবে ছড়ানোর জন্য কোনো হোস্ট ফাইলের দরকার হয় না; এটি নেটওয়ার্কের মাধ্যমে একা একাই ছড়িয়ে পড়ে।

iii) ট্রোজান হর্স (Trojan Horse) : ভালো সফটওয়্যারের ছদ্মবেশে থাকা ক্ষতিকারক প্রোগ্রাম।

iv) র্যানসামওয়্যার (Ransomware) : এটি কম্পিউটারের ফাইল এনক্রিপ্ট বা লক করে দেয় এবং আনলক করার জন্য মুক্তিপণ (টাকা) দাবি করে।

v) স্পাইওয়্যার (Spyware) : এটি গোপনে ব্যবহারকারীর ওপর নজরদারি করে এবং তথ্য চুরি করে।

২. সোশ্যাল ইঞ্জিনিয়ারিং (Social Engineering) : এটি প্রযুক্তির চেয়ে মানুষের মনস্তাত্ত্বিক দুর্বলতাকে কাজে লাগিয়ে করা হয়।

i) ফিশিং (Phishing) : বিশ্বাসযোগ্য প্রতিষ্ঠান (যেমন ব্যাংক বা গুগল)-এর নাম করে ভুয়া ইমেইল বা মেসেজ পাঠিয়ে পাসওয়ার্ড চুরি করা।

**** ৩। সাইবার নিরাপত্তার আইন ও বিধির গুরুত্ব আলোচনা কর।**

বাকশির্বো- ২০২৫

উত্তর : আধুনিক বিশ্বে ইন্টারনেটের প্রসার যেমন বেড়েছে, তেমনি সাইবার অপরাধও পাল্লা দিয়ে বেড়েছে। এই অপরাধ নিয়ন্ত্রণ এবং ডিজিটাল জগতকে নিরাপদ রাখার জন্য সাইবার নিরাপত্তা আইন ও বিধি (Cyber Security Laws and Regulations) অত্যন্ত গুরুত্বপূর্ণ।

নিচে সাইবার আইনের গুরুত্ব আলোচনা করা হলো :

১. অপরাধ দমন ও নিয়ন্ত্রণ : বাস্তব জীবনে চুরি বা ডাকাতি করলে যেমন শাস্তির বিধান আছে, ডিজিটাল জগতেও অপরাধের জন্য শাস্তির ব্যবস্থা থাকা জরুরি। সাইবার আইন অপরাধীদের মনে ভীতি সৃষ্টি করে। যখন হ্যাকাররা জানে যে হ্যাকিং বা তথ্য চুরির জন্য জেল বা বড় অঙ্কের জরিমানা হতে পারে, তখন অপরাধের প্রবণতা কমে আসে।

২. ব্যক্তিগত তথ্যের সুরক্ষা : মানুষের ব্যক্তিগত তথ্য, ছবি বা চ্যাট যেন কেউ অপব্যবহার করতে না পারে, তা নিশ্চিত করা আইনের কাজ। ফেসবুক, গুগল বা ব্যাংকের মতো প্রতিষ্ঠানগুলো কীভাবে আমাদের তথ্য ব্যবহার করবে, তার একটি আইনি সীমারেখা বা গাইডলাইন এই আইনের মাধ্যমে ঠিক করে দেওয়া হয়।

৩. ভুক্তভোগীর আইনি প্রতিকার : কেউ যদি সাইবার বুলিং, হ্যাকিং বা অনলাইন প্রতারণার শিকার হয়, তবে সে কার কাছে বিচার চাইবে? সাইবার আইন ভুক্তভোগীকে পুলিশ বা আদালতের মাধ্যমে বিচার পাওয়ার অধিকার ও পথ দেখায়।

৪. ডিজিটাল অর্থনীতি ও ই-কমার্সের বিকাশ : অনলাইন কেনাকাটা বা মোবাইল ব্যাংকিংয়ের ক্ষেত্রে গ্রাহকের আস্থা বা বিশ্বাস সবচেয়ে জরুরি। যদি কোনো আইনি কাঠামো না থাকে, তবে মানুষ অনলাইনে টাকা লেনদেন করতে ভয় পাবে। সাইবার আইন ডিজিটাল লেনদেনের নিরাপত্তা নিশ্চিত করে দেশের অর্থনীতিকে সচল রাখে।

৫. জাতীয় নিরাপত্তা রক্ষা : সাইবার সন্ত্রাসীরা দেশের বিদ্যুৎ কেন্দ্র, ব্যাংক বা সরকারি সার্ভারে হামলা চালিয়ে অচল করে দিতে পারে। রাষ্ট্রবিরোধী

গুজব বা প্রোপাগান্ডা ছড়াতে পারে। এসব কর্মকাণ্ডকে দেশদ্রোহী অপরাধ হিসেবে গণ্য করে কঠোর ব্যবস্থা নেওয়ার জন্য সাইবার আইন অপরিহার্য।

৬. মেধা সম্পত্তির অধিকার রক্ষা : কারো তৈরি করা সফটওয়্যার, গান, সিনেমা বা বই অনুমতি ছাড়া ইন্টারনেটে ছড়িয়ে দেওয়া (পাইরেসি) রোধ করতে এই আইন গুরুত্বপূর্ণ ভূমিকা পালন করে।

বাংলাদেশের প্রেক্ষাপট :

বাংলাদেশে বর্তমানে 'সাইবার নিরাপত্তা আইন, ২০২৩' (Cyber Security Act, ২০২৩) বলবৎ রয়েছে (যা আগে ডিজিটাল নিরাপত্তা আইন ছিল)। এই আইনের আওতায় হ্যাকিং, ভুয়া তথ্য ছড়ানো, এবং অনলাইন প্রতারণার জন্য বিভিন্ন মেয়াদে কারাদণ্ড ও অর্থদণ্ডের বিধান রয়েছে।

*** ৪। সাইবার নিরাপত্তা ও তথ্য নিরাপত্তার মধ্যে পার্থক্য লেখ।

বাকশির্ষো- ২০২১, ২২

উত্তর : সাইবার নিরাপত্তা (Cyber Security) এবং তথ্য নিরাপত্তা (Information Security বা InfoSec) শব্দ দুটি অনেক সময় একই অর্থে ব্যবহৃত হলেও এদের মধ্যে সূক্ষ্ম ও মৌলিক কিছু পার্থক্য রয়েছে।

বিষয়	সাইবার নিরাপত্তা	তথ্য নিরাপত্তা
১. মূল লক্ষ্য	মূলত অনলাইন বা ডিজিটাল মাধ্যমে থাকা ডেটাকে বাহ্যিক আক্রমণ (যেমন: হ্যাকিং) থেকে রক্ষা করা।	যেকোনো ধরনের তথ্য যেন ভুল হাতে না পড়ে বা নষ্ট না হয় তা নিশ্চিত করা।

২. পরিধি	এটি শুধুমাত্র ডিজিটাল বা সাইবার জগতের মধ্যে সীমাবদ্ধ।	এর পরিধি অনেক বড়; ডিজিটাল ডেটার পাশাপাশি কাগজের ফাইল বা হার্ডকপিও এর অন্তর্ভুক্ত।
৩. সুরক্ষার ধরন	নেটওয়ার্ক, ডিভাইস এবং সফটওয়্যারকে সাইবার ক্রাইম থেকে রক্ষা করে।	তথ্যের গোপনীয়তা, অখণ্ডতা এবং প্রাপ্যতা নিশ্চিত করে।
৪. উদাহরণ	ফায়ারওয়াল ব্যবহার, ম্যালওয়্যার প্রতিরোধ বা ফিশিং লিংকে ক্লিক করা থেকে বিরত থাকা।	আলমারিতে গুরুত্বপূর্ণ ফাইল তালাবদ্ধ করে রাখা, পাসওয়ার্ড নীতি মেনে চলা বা ডেটা এনক্রিপশন।

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

* ১। সিস্টেম নিরাপত্তা বলতে কী বুঝায়?

উত্তর : সিস্টেম নিরাপত্তা (System Security) বলতে একটি কম্পিউটার সিস্টেমের হার্ডওয়্যার, সফটওয়্যার এবং এর মধ্যে থাকা ডাটাকে অননুমোদিত প্রবেশ, ক্ষতি বা চুরি থেকে রক্ষা করার সামগ্রিক প্রক্রিয়াকে বোঝায়।

*** ২। কাজ লেখ; IPS, VPN?

বাকাশিবো- ২০২৫

উত্তর : **IPS :** IPS (Intrusion Prevention System) বা অনুপ্রবেশ প্রতিরোধ ব্যবস্থা হলো একটি অত্যন্ত গুরুত্বপূর্ণ ডিভাইস বা সফটওয়্যার। এটি নেটওয়ার্ক ট্রাফিক প্রতিনিয়ত মনিটর করে এবং কোনো ক্ষতিকারক বা সন্দেহজনক কার্যকলাপ শনাক্ত করার সাথে সাথে তা স্বয়ংক্রিয়ভাবে বন্ধ করে দেয়।

VPN : VPN (Virtual Private Network) বা ভার্চুয়াল প্রাইভেট নেটওয়ার্ক একটি শক্তিশালী ঢাল হিসেবে কাজ করে। এটি পাবলিক ইন্টারনেট ব্যবহারের সময় আপনার ডাটাকে একটি সুরক্ষিত এবং এনক্রিপ্টেড (Encrypted) টানেলের মধ্য দিয়ে পাঠায়।

**** ৩। ফায়ারওয়াল (Firewall) কী?**

উত্তর : ফায়ারওয়াল হলো সাইবার নিরাপত্তার একটি অতি গুরুত্বপূর্ণ অংশ, যা একটি সুরক্ষিত অভ্যন্তরীণ নেটওয়ার্ক এবং একটি অনিরাপদ বাহ্যিক নেটওয়ার্কের (যেমন- ইন্টারনেট) মধ্যে দেয়াল বা প্রহরী হিসেবে কাজ করে।

**** ৪। ফায়ারওয়াল প্রধানত কয় প্রকার ও কী কী?**

বাকাশিবো- ২০২৪পরি

উত্তর : কাজের পদ্ধতি বা ফিল্টারিং প্রযুক্তির ওপর ভিত্তি করে ফায়ারওয়াল প্রধানত ৫ প্রকার যথা;

- i) প্যাকেট ফিল্টারিং ফায়ারওয়াল (Packet Filtering Firewall)
- ii) সার্কিট-লেভেল গেটওয়ে (Circuit-Level Gateway)
- iii) স্টেটফুল ইন্সপেকশন ফায়ারওয়াল (Stateful Inspection Firewall)
- iv) প্রক্সি ফায়ারওয়াল বা অ্যাপ্লিকেশন ফায়ারওয়াল (Proxy Firewall)
- v) নেক্সট-জেনারেশন ফায়ারওয়াল (Next-Generation Firewall - NGFW)

**** ৫। Treat (হুমকি) কী?**

উত্তর : Threat বা হুমকি বলতে এমন কোনো সম্ভাব্য বিপদ বা ঘটনাকে বোঝায়, যা কোনো কম্পিউটার সিস্টেম, নেটওয়ার্ক বা তথ্যের ক্ষতি করতে পারে। সহজ কথায়, ডিজিটাল জগতের যেকোনো ক্ষতিকারক কর্মকাণ্ড বা

পরিস্থিতি, যা তথ্যের গোপনীয়তা, অখণ্ডতা বা প্রাপ্যতা নষ্ট করার ক্ষমতা রাখে, তাকেই হুমকি বলা হয়।

*** ৬। DDoS কী?

বাকশিবো- ২০২৪'পরি, ২৫

উত্তর : DDoS এর পূর্ণরূপ হলো Distributed Denial of Service.

এটি এমন এক ধরনের সাইবার আক্রমণ, যেখানে একটি নির্দিষ্ট ওয়েবসাইট, সার্ভার বা নেটওয়ার্ককে লক্ষ্য করে অসংখ্য ভুয়া ট্রাফিক বা রিকোয়েস্ট পাঠানো হয়। এর ফলে ওই সার্ভারটি অতিরিক্ত লোড সহ্য করতে না পেরে স্লো হয়ে যায় বা পুরোপুরি বন্ধ (Crash) হয়ে যায়।

SOS

সংক্ষিপ্ত প্রশ্নোত্তর :

* ১। সিস্টেম ও নেটওয়ার্ক নিরাপত্তার প্রধান দিকগুলো কী কী?

বাকশিবো- ২০২৫

উত্তর : সিস্টেম নিরাপত্তার প্রধান দিকগুলো নিম্নরূপঃ

- i) অ্যাক্সেস কন্ট্রোল (Access Control)
- ii) ইউজার প্রোফাইল ও প্রিভিলেজ ম্যানেজমেন্ট
- iii) ফাইল সিস্টেম ও ডাটা সুরক্ষা
- iv) ম্যালওয়্যার ও থ্রেট সুরক্ষা (Threat Protection)
- v) সিস্টেম অডিটিং ও মনিটরিং (Auditing, Logging)
- vi) নিয়মিত আপডেট ও প্যাচ ম্যানেজমেন্ট

vii) ব্যাকআপ ও ডিজাস্টার রিকভারি

নেটওয়ার্ক নিরাপত্তার প্রধান দিকগুলো নিম্নরূপ :

i) ফায়ারওয়াল (Firewall)

ii) নেটওয়ার্ক এক্সেস কন্ট্রোল (Network Access Control - NAC)

iii) ভার্চুয়াল প্রাইভেট নেটওয়ার্ক (VPN)

iv) অনুপ্রবেশ শনাক্তকরণ ও প্রতিরোধ ব্যবস্থা (IDS/IPS)

v) নেটওয়ার্ক সেগমেন্টেশন (Network Segmentation)

vi) ওয়্যারলেস সিকিউরিটি (Wireless Security)

vii) অ্যাপলিকেশন সিকিউরিটি (Application Security)

**** ২। ফায়ারওয়ালের কাজ লেখ।**

উত্তর : ফায়ারওয়ালের কাজগুলো নিম্নরূপ :

১. ইনকামিং ট্রাফিক ফিল্টারিং : ফায়ারওয়ালের সবচেয়ে গুরুত্বপূর্ণ কাজ হলো ইন্টারনেট থেকে আপনার কম্পিউটারে আসা সমস্ত তথ্য বা ডেটা প্যাকেট পরীক্ষা করা। এটি ক্ষতিকারক ওয়েবসাইট বা হ্যাকারদের পাঠানো সন্দেহজনক রিকোয়েস্টগুলো শনাক্ত করে এবং সেগুলোকে আটকে দেয়।

২. অননুমোদিত প্রবেশ রোধ : হ্যাকাররা সবসময় ইন্টারনেটের মাধ্যমে বিভিন্ন কম্পিউটারে ঢোকার জন্য 'খোলা পথ' বা পোর্ট (Port) খোঁজে। ফায়ারওয়াল অপ্রয়োজনীয় সব পোর্ট বন্ধ করে রাখে, ফলে হ্যাকাররা চাইলেও আপনার সিস্টেমে অনধিকার প্রবেশ করতে পারে না।

৩. **আউটগোয়িং ট্রাফিক মনিটরিং :** ফায়ারওয়াল শুধু বাইর থেকে আসা তথ্যই চেক করে না, বরং আপনার কম্পিউটার থেকে বাইরে কী তথ্য যাচ্ছে তাও নজরে রাখে। যদি কোনো ম্যালওয়্যার আপনার অজান্তে আপনার গোপন তথ্য ইন্টারনেটে পাচার করার চেষ্টা করে, তবে ফায়ারওয়াল তা শনাক্ত করে বাধা দিতে পারে।

৪. **ম্যালওয়্যার ও ভাইরাসের বিস্তার রোধ :** অনেক ভাইরাস বা ওয়ার্ম নেটওয়ার্কের মাধ্যমে এক কম্পিউটার থেকে অন্য কম্পিউটারে ছড়িয়ে পড়ে।

ফায়ারওয়াল এই ধরনের ক্ষতিকারক সফটওয়্যারের যাতায়াত পথ বন্ধ করে দিয়ে নেটওয়ার্কের অন্যান্য ডিভাইসকে সুরক্ষিত রাখে।

৫. **প্রক্সি ও কন্টেন্ট ফিল্টারিং :** অনেক উন্নত ফায়ারওয়াল (যেমন- কর্পোরেট ফায়ারওয়াল) নির্দিষ্ট কিছু ওয়েবসাইট বা অ্যাপ্লিকেশন ব্লক করতে পারে। উদাহরণস্বরূপ, কোনো অফিস চাইলে তাদের নেটওয়ার্কে সোশ্যাল মিডিয়া সাইটগুলো ব্লক করে রাখতে পারে, যা ফায়ারওয়ালের মাধ্যমেই করা হয়।

৬. **আইপি অ্যাড্রেস ব্লকিং :** যদি কোনো নির্দিষ্ট আইপি অ্যাড্রেস থেকে বারবার সাইবার আক্রমণের চেষ্টা করা হয়, তবে ফায়ারওয়াল সেই নির্দিষ্ট আইপি-কে কালো তালিকাভুক্ত (Blacklist) করে চিরতরে ব্লক করে দিতে পারে।

**** ৩। NGFW ব্যাখ্যা কর।**

বাকাশির্বো- ২০২৫

উত্তর : NGFW-এর পূর্ণরূপ হলো Next-Generation Firewall (নেক্সট-জেনারেশন ফায়ারওয়াল)। এটি হলো প্রথাগত বা ট্র্যাডিশনাল ফায়ারওয়ালের একটি উন্নত এবং আধুনিক সংস্করণ, যা বর্তমান যুগের জটিল সাইবার হামলা মোকাবিলা করার জন্য তৈরি করা হয়েছে। সাধারণ ফায়ারওয়াল যেখানে কেবল আইপি (IP) অ্যাড্রেস এবং পোর্ট নম্বর দেখে ডেটা ফিল্টার করত, সেখানে NGFW ডেটার গভীরে গিয়ে পরীক্ষা করতে পারে। আধুনিক হ্যাকাররা এখন সাধারণ পোর্ট বা আইপি ব্লক এড়িয়ে যেতে পারে। তারা ম্যালওয়্যারকে সাধারণ ডেটা প্যাকেটের ভেতরে লুকিয়ে পাঠায়। এই ধরনের সুক্ষ্ম এবং শক্তিশালী আক্রমণ (যেমন- Ransomware) প্রতিরোধের জন্য NGFW বর্তমানে প্রতিটি বড় প্রতিষ্ঠানের জন্য অপরিহার্য।

SOS

রচনামূলক প্রশ্নোত্তর :

**** ১। ফায়ারওয়ালের প্রকারভেদ বর্ণনা কর।**

উত্তর : কাজের পদ্ধতি বা ফিল্টারিং প্রযুক্তির ওপর ভিত্তি করে ফায়ারওয়াল প্রধানত ৫ প্রকার যথা,

১) প্যাকেট ফিল্টারিং ফায়ারওয়াল (Packet Filtering Firewall)

: এটি সবচেয়ে পুরনো এবং সাধারণ ধরনের ফায়ারওয়াল। এটি প্রতিটি ডেটা প্যাকেটের আইপি (IP) অ্যাড্রেস, পোর্ট নম্বর এবং প্রোটোকল চেক

করে। যদি তা আগে থেকে সেট করা নিয়মের সাথে মিলে যায়, তবেই তাকে ঢুকতে দেয়।

সুবিধাঃ এটি খুব দ্রুত কাজ করে।

২) সার্কিট-লেভেল গেটওয়ে (**Circuit-Level Gateway**) : এটি ডেটা প্যাকেটের ভেতরের তথ্য পরীক্ষা করার বদলে নেটওয়ার্কের সংযোগ বা সেশন (TCP Handshake) বৈধ কি না তা যাচাই করে। এটি খুব দ্রুত কাজ করলেও ডেটার ভেতরের ম্যালওয়্যার শনাক্ত করতে পারে না।

৩) স্টেটফুল ইন্সপেকশন ফায়ারওয়াল (**Stateful Inspection Firewall**) : এটি প্যাকেট ফিল্টারিং এবং সার্কিট-লেভেল-উভয় প্রযুক্তির সমন্বয়ে কাজ করে। এটি শুধু আইপি চেক করে না, বরং পুরো কানেকশন বা সেশনের ইতিহাস মনে রাখে এবং যাচাই করে যে ট্রাফিকটি কোনো বিশ্বস্ত সূত্র থেকে আসছে কি না।

৪) প্রক্সি ফায়ারওয়াল বা অ্যাপ্লিকেশন ফায়ারওয়াল (**Proxy Firewall**) : এটি ইন্টারনেটের সাথে সরাসরি সংযোগ হতে দেয় না। হ্যাকার এবং আপনার সিস্টেমের মাঝে এটি একটি "মধ্যস্থতাকারী" (Mediator) হিসেবে কাজ করে। এটি ডেটা প্যাকেটের একদম গভীরে (Application Layer) গিয়ে পরীক্ষা করে।

উদাহরণ : আপনার অফিসের কম্পিউটার থেকে কোনো সাইটে ঢুকলে সেটি আগে প্রক্সি সার্ভারে যায়, তারপর ইন্টারনেটে।

৫) নেক্সট-জেনারেশন ফায়ারওয়াল (**Next-Generation Firewall - NGFW**) : এটি বর্তমানে সবচেয়ে শক্তিশালী ফায়ারওয়াল। এতে

সাধারণ ফায়ারওয়ালের সব ফিচারের পাশাপাশি IPS (Intrusion Prevention System) এবং Deep Packet Inspection (DPI) করার ক্ষমতা থাকে। এটি আধুনিক এবং জটিল সাইবার হামলা রুখতে সক্ষম।

*** ২। "বিভিন্ন লেয়ারে সাইবার আক্রমণ ঘটতে পারে"- এর যথার্থতা ব্যাখ্যা কর।

বাকশির্বো- ২০২৫

উত্তর : সাইবার নিরাপত্তার ক্ষেত্রে আমরা সাধারণত OSI Model (Open Systems Interconnection Model) অনুসরণ করি, যার ৭টি লেয়ার বা স্তর রয়েছে। হ্যাকাররা তাদের লক্ষ্য অনুযায়ী এই সাতটি স্তরের যেকোনোটিতে আক্রমণ চালাতে পারে।

নিচে বিভিন্ন লেয়ারে সাইবার আক্রমণের উদাহরণসহ যথার্থতা ব্যাখ্যা করা হলো :

১. ফিজিক্যাল লেয়ার (Physical Layer - Layer 1) : এটি নেটওয়ার্কের সবচেয়ে নিচের স্তর, যেখানে হার্ডওয়্যার এবং ক্যাবল থাকে।
আক্রমণ : তার কেটে ফেলা, ডাটা সেন্টার থেকে হার্ডড্রাইভ চুরি করা, বা ডিভাইসে সরাসরি ক্ষতিকারক কোনো চিপ বা ইউএসবি (USB) লাগানো।
প্রভাব : পুরো সিস্টেম বা নেটওয়ার্ক সংযোগ বিচ্ছিন্ন হয়ে যায়।

২. ডাটা লিংক লেয়ার (Data Link Layer - Layer 2) : এই লেয়ারে ডিভাইসগুলোর মধ্যে সরাসরি সংযোগ থাকে (যেমনঃ সুইচ বা ওয়াইফাই)।
আক্রমণ : MAC Spoofing ev ARP Poisoning।

এর মাধ্যমে হ্যাকার নিজেকে বৈধ ইউজার হিসেবে নেটওয়ার্কে তুলে ধরে তথ্য চুরি করে।

৩. নেটওয়ার্ক লেয়ার (Network Layer - Layer 3) : এই স্তরে আইপি (IP) অ্যাড্রেস এবং রাউটিং কাজ করে।

আক্রমণ : IP Spoofing ev ICMP Flood। হ্যাকাররা আইপি অ্যাড্রেস জাল করে ভুল তথ্য পাঠায় বা নেটওয়ার্ক ট্রাফিক জ্যাম করে দেয়।

উদাহরণ : কোনো নির্দিষ্ট আইপি ব্যবহার করে সার্ভার ডাউন করা।

৪. ট্রান্সপোর্ট লেয়ার (Transport Layer - Layer 4) : এই লেয়ারটি ডেটা আদান-প্রদানের নির্ভরযোগ্যতা নিশ্চিত করে (TCP/UDP)।

আক্রমণ : SYN Flood ev TCP Hijacking। হ্যাকাররা অসংখ্য ফেক রিকোয়েস্ট পাঠিয়ে সার্ভারের কানেকশন জ্যাম করে দেয়, যা DoS/DDoS আক্রমণের অংশ।

৫. সেশন লেয়ার (Session Layer - Layer 5) : এই স্তরটি দুই ডিভাইসের মধ্যে সংযোগ বা সেশন তৈরি এবং নিয়ন্ত্রণ করে।

আক্রমণঃ Session Hijacking। আপনার অনলাইন ব্যাংকিং বা ফেসবুক লগইন থাকা অবস্থায় হ্যাকার যদি আপনার "সেশন আইডি" চুরি করে নেয়, তবে সে আপনার পাসওয়ার্ড ছাড়াই অ্যাকাউন্টে ঢুকে পড়তে পারে।

৬. প্রেজেন্টেশন লেয়ার (Presentation Layer - Layer 6) : এটি ডেটাকে এনক্রিপশন বা ডিক্রিপশন করার কাজ করে।

আক্রমণ : Encryption Attack বা ম্যালওয়্যারের মাধ্যমে এনক্রিপশন প্রোটোকল ভেঙে ফেলা। এর ফলে হ্যাকার আপনার গোপন তথ্য সাধারণ টেক্সটে রূপান্তর করে পড়ে নিতে পারে।

৭. অ্যাপ্লিকেশন লেয়ার (Application Layer - Layer 7) : এটি ব্যবহারকারীর সবচেয়ে কাছাকাছি স্তর (যেমনঃ ক্রোম ব্রাউজার, ইমেইল বা ফেসবুক অ্যাপ)। বর্তমানে সবচেয়ে বেশি আক্রমণ এখানেই ঘটে।

আক্রমণ : SQL Injection, Cross-Site Scripting (XSS), Ges Phishing.

প্রভাব : হ্যাকার সরাসরি ডেটাবেস থেকে তথ্য নিয়ে নিতে পারে বা ম্যালওয়্যার ছড়িয়ে দিতে পারে

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

*১। পেনেট্রেশন টেস্টিং বলতে কী বুঝায়?

উত্তর : পেনেট্রেশন টেস্টিং (Penetration Testing) বা সংক্ষেপে Pen Testing হলো কোনো একটি কম্পিউটার সিস্টেম, নেটওয়ার্ক বা ওয়েব অ্যাপ্লিকেশনের নিরাপত্তা ব্যবস্থা পরীক্ষা করার একটি অনুমোদিত ও পরিকল্পিত প্রক্রিয়া। একে অনেক সময় 'এথিক্যাল হ্যাকিং' বা 'হোয়াইট হ্যাট হ্যাকিং'-ও বলা হয়।

** ২। ওয়্যারলেস হ্যাকিং কী?

উত্তর : ওয়্যারলেস হ্যাকিং (Wireless Hacking) বলতে কোনো তারবিহীন নেটওয়ার্ক (যেমন- Wi-Fi, Bluetooth ev RFID) এর নিরাপত্তা ভেঙে সেটির তথ্য চুরি করা বা নেটওয়ার্কে অননুমোদিতভাবে প্রবেশ করাকে বোঝায়।

* ৩। কয়েকটি হ্যাকিং টুলের নাম লেখ।

উত্তর :

- i) Nmap (Network Mapper)
- ii) Wireshark
- iii) Metasploit Framework

- v) John the Ripper
- v) Hashcat
- vi) Burp Suite
- vii) SQLmap
- viii) Aircrack-ng ইত্যাদি।

**** ৪। লগ ফাইল বলতে কী বুঝ?**

বাকশিবো- ২০২৫

উত্তর : সাইবার নিরাপত্তা এবং কম্পিউটার সিস্টেমের ভাষায় লগ ফাইল (Log File) হলো একটি ডিজিটাল ডায়েরি বা রেকর্ডের খাতা। একটি কম্পিউটার সিস্টেম, অ্যাপ্লিকেশন বা নেটওয়ার্কে কখন কী ঘটছে, তার প্রতিটি ঘটনার বিস্তারিত বিবরণ সময়সহ এই ফাইলে স্বয়ংক্রিয়ভাবে জমা হয়।

SOS

সংক্ষিপ্ত প্রশ্নোত্তর :

*** ১। ভালনারেবিলিটি অ্যাসেসমেন্ট ও পেনেট্রেশন টেস্টিং এর মধ্যে পার্থক্য লেখ।**

বিষয়	ভালনারেবিলিটি অ্যাসেসমেন্ট	পেনেট্রেশন টেস্টিং
১. মূল উদ্দেশ্য	সিস্টেমে কোন কোন দুর্বলতা বা ছিদ্র আছে তা খুঁজে বের করা এবং একটি তালিকা তৈরি করা।	দুর্বলতাগুলো ব্যবহার করে সিস্টেমে প্রবেশ করা সম্ভব কি না বা কতটা ক্ষতি করা যায় তা পরীক্ষা করা।

২. পদ্ধতি	এটি মূলত একটি স্ক্যানিং প্রক্রিয়া, যেখানে স্বয়ংক্রিয় টুল বেশি ব্যবহৃত হয়।	এটি একটি আক্রমণাত্মক প্রক্রিয়া, যেখানে হ্যাকারদের মতো ম্যানুয়ালি আক্রমণ চালিয়ে দেখা হয়।
৩. ফলাফল	দুর্বলতাগুলোর একটি রিপোর্ট প্রদান করে যা মেরামত করা প্রয়োজন।	আক্রমণ কতটা সফল হয়েছে এবং সিস্টেমের গভীরে কতটা প্রবেশ করা গেছে তার প্রমাণসহ রিপোর্ট দেয়।
৪. সময়কাল	এটি দ্রুত সম্পন্ন করা যায় (যেমন: প্রতি সপ্তাহে বা মাসে একবার)।	এটি করতে অনেক বেশি সময়ের প্রয়োজন হয় এবং সাধারণত বছরে একবার বা বিশেষ প্রয়োজনে করা হয়।
৫. জনবল	সাধারণ আইটি কর্মীরা বিভিন্ন টুল ব্যবহার করে এটি করতে পারেন।	এটি করার জন্য দক্ষ এথিক্যাল হ্যাকার বা নিরাপত্তা বিশেষজ্ঞের প্রয়োজন হয়।

২। ওয়্যারলেস হ্যাকিং এর সাধারণ পদ্ধতিগুলো লেখ।

উত্তর : ওয়্যারলেস হ্যাকিং এর সাধারণ পদ্ধতিগুলো নিম্নে লেখা হলো :

১) পাসওয়ার্ড ক্র্যাকিং (Password Cracking) :

i) **Brute Force Attack** : হ্যাকাররা বিভিন্ন পাসওয়ার্ডের কম্বিনেশন দিয়ে বারবার চেষ্টা করে সঠিক পাসওয়ার্ড বের করার চেষ্টা করে।

ii) Dictionary Attack : একটি নির্দিষ্ট তালিকায় থাকা হাজার হাজার কমন পাসওয়ার্ড ব্যবহার করে অটোমেটেড উপায়ে পরীক্ষা করা হয়।

২) ইভিল টুইন অ্যাটাক (Evil Twin Attack) : হুবহু আসল ওয়াইফাইয়ের মতো দেখতে একটি ভুয়া বা ডামি ওয়াইফাই নেটওয়ার্ক তৈরি করা হয়। ব্যবহারকারী ভুল করে তাতে কানেক্ট করলে তার পাসওয়ার্ড হ্যাকারের কাছে চলে যায়।

৩) প্যাকেট স্নিফিং (Packet Sniffing) : বাতাসে ভেসে থাকা ডেটা প্যাকেটগুলো হ্যাকাররা বিভিন্ন টুলের সাহায্যে ইন্টারসেপ্ট বা 'শুঁকে' দেখে। এর মাধ্যমে এনক্রিপ্ট না করা তথ্য বা লগইন আইডি-পাসওয়ার্ড চুরি হতে পারে।

৪) ডাই-অথেন্টিকেশন অ্যাটাক (Deauthentication Attack) : এই পদ্ধতিতে হ্যাকার কোনো নির্দিষ্ট ডিভাইসকে তার বর্তমান ওয়াইফাই নেটওয়ার্ক থেকে বিচ্ছিন্ন করে দেয়। ডিভাইসটি যখন আবার কানেক্ট করার চেষ্টা করে, তখন হ্যাকার সেই 'Handshake' ডেটা সংগ্রহ করে পাসওয়ার্ড ক্র্যাক করার চেষ্টা করে।

৫) WPS দুর্বলতা (WPS Exploitation) : অনেক রাউটারে WPS পিন অপশন থাকে। হ্যাকাররা ৪ সংখ্যার এই পিনটি সহজেই ভেঙে রাউটারে ঢুকে পড়তে পারে।

৬) ম্যান-ইন-দ্য-মিডল (MITM) : হ্যাকারের অবস্থান হয় রাউটার এবং ব্যবহারকারীর ঠিক মাঝখানে। ফলে ব্যবহারকারী কী দেখছেন বা কী টাইপ করছেন, তার সবকিছুই হ্যাকার দেখতে পায়।

*** ৩। লগ ফাইলের ব্যবহার লেখ।

বাকাশিবো- ২০২৫

উত্তর : লগ ফাইলের ব্যবহার নিম্নে লেখা হলো :

- i) **ত্রুটি খুঁজে বের করা (Troubleshooting) :** সিস্টেম বা কোনো অ্যাপ ত্রুটি করলে কেন এমন হলো, তা লগ ফাইল দেখে বোঝা যায়। এতে সমস্যার মূল কারণ (Root Cause) দ্রুত শনাক্ত করা সম্ভব হয়।
- ii) **নিরাপত্তা নিশ্চিত করা (Security Monitoring) :** কোন আইডি থেকে কখন লগইন করা হয়েছে, কোনো সন্দেহজনক আইপি অ্যাড্রেস থেকে প্রবেশের চেষ্টা হয়েছে কি না—এই সব তথ্য লগ ফাইলে থাকে। এটি সাইবার আক্রমণ বা হ্যাকিং শনাক্ত করতে সাহায্য করে।
- iii) **সিস্টেম পারফরম্যান্স ট্র্যাকিং (Performance Tracking) :** সিস্টেমটি কত দ্রুত কাজ করছে বা কোথায় গিয়ে স্লো হয়ে যাচ্ছে, তা লগের মাধ্যমে পর্যবেক্ষণ করা যায়। এর ফলে সিস্টেমের কার্যক্ষমতা উন্নত করা সম্ভব হয়।
- iv) **ফরেনসিক অ্যানালাইসিস (Forensic Analysis) :** কোনো সাইবার অপরাধ সংঘটিত হওয়ার পর, হ্যাকার কোন পথে ঢুকেছিল এবং কী কী ডেটা চুরি করেছে, তা প্রমাণসহ বের করতে লগ ফাইল ব্যবহৃত হয়।
- v) **অডিটিং এবং কমপ্লায়েন্স (Auditing) :** প্রতিষ্ঠানগুলোতে কে কখন ডাটাবেজ পরিবর্তন করেছে বা সেনসিটিভ ফাইলে হাত দিয়েছে, তার একটি অফিশিয়াল রেকর্ড রাখার জন্য লগ ফাইল ব্যবহার করা হয়।

SOS**রচনামূলক প্রশ্নোত্তর :**

* ১। পেনেট্রেশন টেস্টিং এর কৌশলসমূহ বর্ণনা কর।

উত্তর : নিম্নে পেনেট্রেশন টেস্টিং এর কৌশলসমূহ বর্ণনা করা হলো :

১) **পাসওয়ার্ড আক্রমণ (Password Attack) :** পেনেট্রেশন টেস্টিং-এ পাসওয়ার্ড আক্রমণ (Password Attack) হলো এমন একটি প্রক্রিয়া যার মাধ্যমে কোনো সিস্টেম, অ্যাপ্লিকেশন বা নেটওয়ার্কের ব্যবহারকারীর পাসওয়ার্ড ভেঙে বা অনুমান করে অনধিকার প্রবেশ করার চেষ্টা করা হয়। সাইবার নিরাপত্তায় এটি অত্যন্ত গুরুত্বপূর্ণ, কারণ হ্যাকাররা প্রায়ই এই পদ্ধতি ব্যবহার করে প্রাথমিক অ্যাক্সেস পায়। যেমন : ব্রুট ফোর্স অ্যাটাক (Brute Force Attack), ডিকশনারি অ্যাটাক (Dictionary Attack), রেইনবো টেবিল অ্যাটাক (Rainbow Table Attack), ক্রেডেনশিয়াল স্টাফিং (Credential Stuffing), স্প্রেইং অ্যাটাক (Password Spraying)

২) **পেনেট্রেশন টেস্টিং-এ সোশ্যাল ইঞ্জিনিয়ারিং : (Social Engineering)** হলো এমন একটি কৌশল যেখানে কোনো কারিগরি বা সফটওয়্যার হ্যাকিংয়ের বদলে সরাসরি মানুষকে ধোঁকা দিয়ে বা মনস্তাত্ত্বিক কারসাজি (Psychological Manipulation) করে গোপন তথ্য হাতিয়ে নেওয়া হয়।

সোশ্যাল ইঞ্জিনিয়ারিংয়ের সাধারণ পদ্ধতিসমূহ :

i) ফিশিং (Phishing) : ইমেইল বা মেসেজের মাধ্যমে ভুয়া লিঙ্ক পাঠিয়ে ব্যবহারকারীর আইডি-পাসওয়ার্ড বা ক্রেডিট কার্ডের তথ্য চুরি করা। (যেমন : ব্যাংক থেকে ইমেইল আসার ভান করা)।

ii) ভিশিং (Vishing) : ফোনের মাধ্যমে ভুয়া পরিচয় দিয়ে (যেমনঃ কাস্টমার কেয়ার বা আইটি সাপোর্ট) তথ্য আদায় করা।

iii) স্মিশিং (Smishing) : এসএসএম (SMS)-এর মাধ্যমে ক্ষতিকারক লিঙ্ক পাঠিয়ে হ্যাক করা।

iv) বেইটিং (Baiting) : লোভ দেখানো। যেমন : রাস্তার ধারে একটি পেনড্রাইভ ফেলে রাখা যাতে 'বেতন লিস্ট' লেখা থাকে। কেউ কৌতূহলী হয়ে এটি তার কম্পিউটারে লাগালেই ম্যালওয়্যার ঢুকে যায়।

v) টেইলগেটিং (Tailgating) : কোনো অনুমোদিত ব্যক্তির ঠিক পেছনে পেছনে হেঁটে সিকিউরিটি গেট দিয়ে নিষিদ্ধ এলাকায় ঢুকে পড়া।

vi) প্রি-টেক্সটিং (Pretexting) : একটি সাজানো গল্প বা মিথ্যা প্রেক্ষাপট তৈরি করে বিশ্বাস অর্জন করা এবং তথ্য বের করে নেওয়া।

৩) নেটওয়ার্ক আক্রমণ (Network Attack) : পেনেট্রেশন টেস্টিং-এ নেটওয়ার্ক আক্রমণ (Network Attack) হলো এমন একটি প্রক্রিয়া যেখানে একটি প্রতিষ্ঠানের নেটওয়ার্ক অবকাঠামো (যেমনঃ রাউটার, সুইচ, সার্ভার এবং হাব) এর দুর্বলতাগুলো খুঁজে বের করে সেগুলোতে আঘাত হানা হয়। এর মূল লক্ষ্য থাকে নেটওয়ার্কের নিরাপত্তা ভেদ করে তথ্য চুরি করা বা সিস্টেমকে অচল করে দেওয়া।

নেটওয়ার্ক আক্রমণের সাধারণ পদ্ধতিসমূহ :

i) **প্যাকেট স্নিফিং (Packet Sniffing)** : নেটওয়ার্কের ভেতর দিয়ে যে ডেটা আদান-প্রদান হচ্ছে, তা মাঝপথে চুরি করে দেখা। হ্যাকাররা Wireshark-এর মতো টুল ব্যবহার করে এনক্রিপ্ট না করা পাসওয়ার্ড বা গোপন তথ্য দেখে ফেলে।

ii) **ম্যান-ইন-দ্য-মিডল (MITM)** : এখানে হ্যাকার দুই জন ব্যবহারকারীর যোগাযোগের মাঝখানে অবস্থান করে এবং উভয়ের অজান্তে তথ্য পরিবর্তন বা চুরি করে।

iii) **ডস ও ডিডস অ্যাটাক (DoS DDoS)** : কোনো সার্ভার বা নেটওয়ার্কে এত বেশি ফেক রিকোয়েস্ট পাঠানো হয় যে সেটি জ্যাম হয়ে যায় এবং সাধারণ ব্যবহারকারীরা সেটি ব্যবহার করতে পারে না।

iv) **আইপি স্পুফিং (IP Spoofing)** : হ্যাকার নিজের আসল আইপি অ্যাড্রেস লুকিয়ে একটি বিশ্বস্ত আইপি ব্যবহার করে নেটওয়ার্কে প্রবেশ করে।

v) **পোর্ট স্ক্যানিং (Port Scanning)** : নেটওয়ার্কের কোন কোন পোর্ট খোলা আছে তা খুঁজে বের করা। খোলা পোর্ট মানেই হ্যাকারের জন্য প্রবেশের একটি সম্ভাব্য দরজা।

**** ২। VAPT রিপোর্টের মূল বিষয়বস্তু বর্ণনা কর।**

উত্তর : একটি VAPT (Vulnerability Assessment and Penetration Testing) রিপোর্ট হলো একটি গুরুত্বপূর্ণ ডকুমেন্ট, যা প্রতিষ্ঠানের নিরাপত্তা ব্যবস্থার বর্তমান অবস্থা এবং চিহ্নিত দুর্বলতাগুলো

তুলে ধরে। এই রিপোর্টটি মূলত টেকনিক্যাল টিম এবং ম্যানেজমেন্ট-উভয় পক্ষের বোঝার উপযোগী করে তৈরি করা হয়। একটি আদর্শ VAPT রিপোর্টের মূল বিষয়বস্তুগুলো নিচে ধারাবাহিকভাবে বর্ণনা করা হলোঃ

১. এক্সিকিউটিভ সামারি (Executive Summary) : এটি রিপোর্টের সবচেয়ে গুরুত্বপূর্ণ অংশ, যা মূলত অ-কারিগরি বা ম্যানেজমেন্ট পর্যায়ের ব্যক্তিদের জন্য লেখা হয়। এতে গ্রাফ বা চার্টের মাধ্যমে সিস্টেমের সামগ্রিক নিরাপত্তা অবস্থা দেখানো হয়। প্রধান ঝুঁকিগুলো কী কী এবং সেগুলো ব্যবসার ওপর কী প্রভাব ফেলতে পারে, তার একটি সংক্ষিপ্ত সারসংক্ষেপ থাকে।

২. স্কোপ অব ওয়ার্ক (Scope of Work) :

এখানে উল্লেখ থাকে যে ঠিক কোন কোন সিস্টেমের ওপর পরীক্ষা চালানো হয়েছে। যেমনঃ নির্দিষ্ট আইপি অ্যাড্রেস, ডোমেইন নাম, মোবাইল অ্যাপ বা নেটওয়ার্ক রেঞ্জ।

৩. মেথডোলজি (Methodology) : টেস্টটি করার সময় কোন আন্তর্জাতিক স্ট্যান্ডার্ড বা পদ্ধতি অনুসরণ করা হয়েছে তা এখানে থাকে। যেমনঃ OWASP (ওয়েব অ্যাপ্লিকেশনের জন্য), OSSTMM বা NIST ফ্রেমওয়ার্ক।

৪. ভালনারেবিলিটি ডিটেইলস (Vulnerability Details) : এটি রিপোর্টের মূল অংশ যেখানে প্রতিটি দুর্বলতার বিস্তারিত থাকে। প্রতিটি দুর্বলতার জন্য নিচের তথ্যগুলো দেওয়া হয় :

i) **রিস্ক রেটিং (Risk Rating)** : দুর্বলতাটি কতটা ভয়াবহ (Critical, High, Medium, Low) ।

ii) **প্রফ অব কনসেপ্ট (PoC)** : হ্যাকার কীভাবে এই দুর্বলতা কাজে লাগিয়ে আক্রমণ করেছে, তার স্ক্রিনশট বা প্রমাণ ।

iii) **প্রভাব (Impact)** : এই দুর্বলতার কারণে কী কী ক্ষতি হতে পারে (যেমনঃ ডেটা চুরি বা সার্ভার ডাউন) ।

৫. **রেমেডিয়েশন বা সমাধান**

(Remediation/Recommendations) : শুধুমাত্র সমস্যা নয়, বরং সেগুলো কীভাবে সমাধান করতে হবে তার বিস্তারিত গাইডলাইন এখানে দেওয়া থাকে । এটি ডেভেলপার বা আইটি অ্যাডমিনদের কাজ সহজ করে দেয় ।

৬. **কনক্লুশন (Conclusion)** : পুরো প্রক্রিয়ার একটি চূড়ান্ত সিদ্ধান্ত এবং ভবিষ্যতে নিরাপত্তা বজায় রাখার জন্য কিছু পরামর্শ দেওয়া হয় ।

অধ্যায়-৪

ডাটা সিকিউরিটি

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

* ১। ডাটাবেস সিকিউরিটি কাকে বলে?

উত্তর : ডাটাবেসে জমা রাখা তথ্য যেন কেউ চুরি করতে না পারে, ভুলভাবে পরিবর্তন করতে না পারে এবং প্রয়োজনে যেন সবসময় পাওয়া যায়—তা নিশ্চিত করাই হলো ডাটাবেস সিকিউরিটি।

*** ২। DES ও AES কী?

বাকাশিবো- ২০২৫

উত্তর : **DES :** Data Encryption Standard(DES) হলো একটি ঐতিহাসিক এবং গুরুত্বপূর্ণ এনক্রিপশন পদ্ধতি, যা ডিজিটাল তথ্যকে সুরক্ষিত করতে ব্যবহৃত হতো। এটি একটি Symmetric-key অ্যালগরিদম, অর্থাৎ এখানে তথ্য এনক্রিপ্ট এবং ডিক্রিপ্ট করার জন্য একই Key ব্যবহার করা হয়।

AES : Advanced Encryption Standard (AES) হলো বর্তমানে বিশ্বের সবচেয়ে জনপ্রিয় এবং শক্তিশালী এনক্রিপশন অ্যালগরিদম।

এটি ইলেকট্রনিক ডাটা বা তথ্যকে কোড এ রূপান্তর করে সুরক্ষিত রাখে।

**** ৩। হ্যাশিং অ্যালগরিদম (Hashing Algorithm) কী?**

উত্তর : হ্যাশিং অ্যালগরিদম হলো একটি গাণিতিক ফাংশন যা যেকোনো দৈর্ঘ্যের ডাটা গ্রহণ করে সেটিকে একটি নির্দিষ্ট দৈর্ঘ্যের অনন্য ডিজিটাল কোডে রূপান্তর করে। এই আউটপুটকে বলা হয় 'হ্যাশ ভ্যালু' বা 'মেসেজ ডাইজেস্ট'।

***** ৪। এন্ড-টু-এন্ড এনক্রিপশন কী?**

বাকশিৰো-২০২৫

উত্তর : এন্ড-টু-এন্ড এনক্রিপশন হলো ডেটা বা তথ্য সুরক্ষার এমন একটি পদ্ধতি, যেখানে শুধুমাত্র প্রেরক (Sender) এবং প্রাপক (Receiver) তথ্যটি পড়তে পারেন। মাঝপথে অন্য কেউ, এমনকি যে কোম্পানি বা সার্ভারের মাধ্যমে মেসেজটি যাচ্ছে, তারাও সেই তথ্য পড়তে পারে না।

**** ৫। ডিজিটাল সার্টিফিকেট (Digital Certificate) বলতে কী বুঝায়?**

উত্তর : ডিজিটাল সার্টিফিকেট হলো ইন্টারনেটে কোনো ব্যক্তি, ওয়েবসাইট বা ডিভাইসের পরিচয় নিশ্চিত করার একটি ইলেকট্রনিক দলিল।

এটি অনেকটা আমাদের বাস্তব জীবনের পাসপোর্ট বা জাতীয় পরিচয়পত্রের মতো কাজ করে।

SOS**সংক্ষিপ্ত প্রশ্নোত্তর :**

**** ১। ডাটা সিকিউরিটি এবং ডাটা প্রাইভেসির মধ্যে পার্থক্য লেখ।**

বিষয়	ডেটা সিকিউরিটি	ডেটা প্রাইভেসি
১.মূল সংজ্ঞা	এটি মূলত তথ্যকে অননুমোদিত প্রবেশ বা সাইবার আক্রমণ থেকে রক্ষা করার প্রক্রিয়া।	এটি মূলত তথ্যের সঠিক ব্যবহার, সংগ্রহ এবং আইনি অধিকার নিশ্চিত করার বিষয়।
২.প্রধান লক্ষ্য	ডেটা যাতে চুরি না হয় বা হ্যাক না হয় তা নিশ্চিত করা।	ডেটা কার সাথে শেয়ার করা হবে এবং ব্যবহারকারী তার তথ্যের ওপর কতটা নিয়ন্ত্রণ পাবেন তা নিশ্চিত করা।
৩. প্রযুক্তিগত দিক	এটি মূলত টেকনিক্যাল ব্যবস্থার ওপর নির্ভরশীল (যেমন: ফায়ারওয়াল, এনক্রিপশন)।	এটি মূলত আইনি এবং নীতিমালার ওপর নির্ভরশীল (যেমন: এউচজ বা গোপনীয়তা নীতি)।
৪.দায়বদ্ধতা	এটি নিশ্চিত করে যে ডেটা "সুরক্ষিত" আছে কি না।	এটি নিশ্চিত করে যে ডেটা "সঠিকভাবে এবং আইন মেনে" ব্যবহার হচ্ছে কি না।

*** ২। ক্রিপ্টোগ্রাফি ব্যাখ্যা কর।

বাকাশিবো- ২০২৫

উত্তর : ক্রিপ্টোগ্রাফি (Cryptography) হলো তথ্যকে একটি গোপন কোডে রূপান্তর করার পদ্ধতি বা শিল্প, যাতে কেবল নির্দিষ্ট ব্যক্তিই সেই তথ্যটি পড়তে বা বুঝতে পারে। এটি মূলত তথ্যের গোপনীয়তা এবং সুরক্ষা নিশ্চিত করার জন্য ব্যবহৃত হয়।

ক্রিপ্টোগ্রাফি মূলত দুই ধরনের **Key** ব্যবহারের ওপর ভিত্তি করে ভাগ করা হয় :

১) **সিমেট্রিক ক্রিপ্টোগ্রাফি (Symmetric Cryptography) :** এখানে তথ্য এনক্রিপ্ট এবং ডিক্রিপ্ট-উভয় কাজের জন্যই একটি মাত্র কবু ব্যবহার করা হয়। এটি দ্রুত কাজ করে কিন্তু কবু টি সুরক্ষিতভাবে আদান-প্রদান করা কঠিন।

উদাহরণ : AES, DES.

২) **অ্যাসিমেট্রিক ক্রিপ্টোগ্রাফি (Asymmetric Cryptography) :** এখানে দুটি আলাদা কবু ব্যবহার করা হয়-একটি 'পাবলিক কী' এবং একটি 'প্রাইভেট কী'। এটি অনেক বেশি নিরাপদ।

উদাহরণ : RSA, ECC.

*** ৩। এনক্রিপ্টেড ডাটা স্টোরেজের সুবিধাসমূহ লেখ।

বাকাশিবো- ২০২৫

উত্তর : এনক্রিপ্টেড ডাটা স্টোরেজের সুবিধাসমূহ নিম্নরূপ :

১. **ডেটা চুরির ঝুঁকি হ্রাস (Protection Against Data Theft)**

: যদি কোনো ল্যাপটপ, পেনড্রাইভ বা সার্ভার হার্ডডিস্ক চুরি হয়ে যায়, তবুও

হ্যাকার বা চোর সেই তথ্য দেখতে পারবে না। কারণ এনক্রিপশন করা ফাইলগুলো তাদের কাছে হিজিবিজি কোড হিসেবে থাকবে।

২. গোপনীয়তা রক্ষা (Enhanced Privacy) : ব্যক্তিগত ছবি, ভিডিও বা প্রতিষ্ঠানের গোপন নথিপত্র অন্য কেউ (এমনকি স্টোরেজ প্রোভাইডার বা আইটি অ্যাডমিনও) দেখতে পারে না। এটি তথ্যের সর্বোচ্চ গোপনীয়তা নিশ্চিত করে।

৩. আইনি বাধ্যবাধকতা পূরণ (Compliance) : অনেক আন্তর্জাতিক আইন (যেমনঃ GDPR বা HIPAA) অনুযায়ী গ্রাহকের তথ্য এনক্রিপ্ট করে রাখা বাধ্যতামূলক। এনক্রিপশন ব্যবহার করলে প্রতিষ্ঠানগুলো বিভিন্ন আইনি ঝামেলা ও জরিমানা থেকে মুক্তি পায়।

৪. ডাটার অখণ্ডতা বজায় রাখা (Data Integrity) : এনক্রিপশন শুধুমাত্র তথ্য লুকায় না, এটি তথ্য পরিবর্তনের চেষ্টাও শনাক্ত করতে পারে। যদি কেউ এনক্রিপ্ট করা ফাইলে কোনো পরিবর্তন করার চেষ্টা করে, তবে ডিক্রিপশন করার সময় তা ধরা পড়বে এবং ফাইলটি ওপেন হবে না।

৫. ক্লাউড স্টোরেজে নিরাপত্তা (Cloud Security) : গুগল ড্রাইভ বা ড্রপবক্সের মতো ক্লাউড সার্ভারে ডাটা রাখার সময় যদি তা এনক্রিপ্ট করা থাকে, তবে ক্লাউড সার্ভিস প্রোভাইডার হ্যাক হলেও আপনার ডাটা নিরাপদ থাকবে।

SOS**রচনামূলক প্রশ্নোত্তর :**

**** ১।** বিভিন্ন ধরনের ডাটা হাইডিং পদ্ধতি আলোচনা কর।

উত্তর : তথ্য গোপন রাখা বা ডাটা হাইডিং (Data Hiding) হলো এমন একটি কৌশল যার মাধ্যমে গোপন তথ্যকে এমনভাবে লুকিয়ে রাখা হয় যাতে অননুমোদিত কেউ এর অস্তিত্বই টের না পায়। সাইবার নিরাপত্তা এবং গোপন যোগাযোগের ক্ষেত্রে এটি অত্যন্ত গুরুত্বপূর্ণ।

নিচে বিভিন্ন ধরনের ডাটা হাইডিং পদ্ধতি সহজ ভাষায় আলোচনা করা হলো :

১. স্টেনোগ্রাফি (Steganography) : এটি ডাটা হাইডিংয়ের সবচেয়ে জনপ্রিয় পদ্ধতি। এতে গোপন তথ্যকে অন্য কোনো সাধারণ ফাইলের (যেমন- ছবি, অডিও বা ভিডিও) ভেতরে এমনভাবে লুকিয়ে রাখা হয় যে বাইরে থেকে দেখলে কিছুই বোঝা যায় না।

i) Image Steganography : ছবির পিক্সেলের ভেতরে টেক্সট বা অন্য ফাইল লুকিয়ে রাখা।

ii) Audio/Video Steganography : অডিও বা ভিডিও ফাইলের অপ্রয়োজনীয় ডাটা স্তরে তথ্য গোপন করা।

২. ক্রিপ্টোগ্রাফি (Cryptography) : অনেকে একে আলাদা মনে করলেও এটি ডাটা হাইডিংয়ের একটি অন্যতম রূপ। এখানে তথ্যের অস্তিত্ব লুকানো হয় না, বরং তথ্যের অর্থ লুকিয়ে ফেলা হয়। সাধারণ টেক্সটকে এমন হিজিবিজি কোডে রূপান্তর করা হয় যা চাবি (Key) ছাড়া পড়া অসম্ভব।

৩. ফাইল মাস্কিং বা রিনেমিং (File Masking) : এটি একটি সহজ পদ্ধতি যেখানে ফাইলের ধরন বা এক্সটেনশন বদলে দেওয়া হয়।

উদাহরণঃ একটি গুরুত্বপূর্ণ .zip ফাইলকে .txt বা .jpg নামে সেভ করে রাখা। এতে সাধারণ কেউ ফাইলটি খুললে শুধু ভুল কোড দেখতে পাবে।

৪. অল্টারনেট ডাটা স্ট্রিম (Alternate Data Streams - ADS) : এটি মূলত উইন্ডোজের NTFS ফাইল সিস্টেমে ব্যবহৃত একটি কৌশল। এখানে একটি ফাইলের আড়ালে অন্য একটি ফাইলকে লুকিয়ে রাখা যায়। বাইরে থেকে ফাইলটির সাইজ বা নাম দেখে বোঝার উপায় থাকে না যে এর ভেতরে অন্য কিছু আছে।

৫. ডিস্ক পার্টিশন বা হিডেন ভলিউম (Hidden Partition) : পুরো হার্ডড্রাইভের একটি নির্দিষ্ট অংশকে এমনভাবে লুকিয়ে ফেলা হয় যা সাধারণ অপারেটিং সিস্টেম বা ফাইল এক্সপ্লোরারে দেখা যায় না। বিশেষ সফটওয়্যার বা পাসওয়ার্ড ছাড়া এই অংশে প্রবেশ করা যায় না।

*** ২। ডাটা এনক্রিপশন অ্যালগরিদম এবং পদ্ধতি আলোচনা কর।

বাকশিবো- ২০২৫

উত্তর : তথ্যকে সুরক্ষিত করার জন্য ডাটা এনক্রিপশন বর্তমানে অপরিহার্য। এটি মূলত গাণিতিক সূত্রের (Algorithm) মাধ্যমে সাধারণ তথ্যকে একটি গোপন কোডে রূপান্তর করে। নিচে প্রধান এনক্রিপশন অ্যালগরিদম এবং পদ্ধতিগুলো সহজ ভাষায় আলোচনা করা হলো :

১. এনক্রিপশনের প্রধান পদ্ধতিসমূহ (Encryption Methods) :

Key ব্যবহারের ওপর ভিত্তি করে এনক্রিপশন মূলত দুই প্রকার যথা :

i) **সিমেট্রিক এনক্রিপশন (Symmetric Encryption)** : এখানে তথ্য লক (এনক্রিপ্ট) এবং আনলক (ডিক্রিপ্ট) করার জন্য একই Key ব্যবহার করা হয়। এটি অত্যন্ত দ্রুত কাজ করে।

উদাহরণ : হার্ডড্রাইভ এনক্রিপশন বা বড় ফাইল ট্রান্সফার।

ii) **অ্যাসিমেট্রিক এনক্রিপশন (Asymmetric Encryption)** : এখানে দুটি আলাদা কী থাকে। একটি 'পাবলিক কী' এবং একটি 'প্রাইভেট কী'।

উদাহরণ : ডিজিটাল সিনেচার, অনলাইন ব্যাংকিং, ব্রাউজিং নিরাপত্তা।

২. জনপ্রিয় এনক্রিপশন অ্যালগরিদমসমূহ (Common Algorithms) :

i) **AES (Advanced Encryption Standard)** : এটি বর্তমানে বিশ্বের সবচেয়ে শক্তিশালী এবং বহুল ব্যবহৃত অ্যালগরিদম। এটি একটি সিমেট্রিক পদ্ধতি।

বৈশিষ্ট্য : এটি 128, 192 বা 256 বিট দৈর্ঘ্যের কী ব্যবহার করে।
ব্যবহার : ওয়াইফাই নিরাপত্তা (WPA2), হোয়াটসঅ্যাপ মেসেজ এবং সরকারি তথ্য রক্ষা।

ii) **DES (Data Encryption Standard)** : এটি 1970-এর দশকে তৈরি প্রথম দিকের অ্যালগরিদম। এটিও একটি সিমেট্রিক পদ্ধতি।
বৈশিষ্ট্য : এর কী সাইজ মাত্র 56-বিট, যা বর্তমানে খুব সহজেই হ্যাক করা যায়। তাই এটি এখন আর ব্যবহৃত হয় না।

iii) RSA (Rivest-Shamir-Adleman) : এটি একটি অত্যন্ত শক্তিশালী অ্যাসিমেট্রিক অ্যালগরিদম।

বৈশিষ্ট্য : এটি বড় বড় মৌলিক সংখ্যা (Prime Numbers) ব্যবহার করে জটিল গাণিতিক সুরক্ষা তৈরি করে।

ব্যবহার : ইমেইল নিরাপত্তা এবং ডিজিটাল সার্টিফিকেটে ব্যবহৃত হয়।

iv) 3DES (Triple DES) : এটি পুরাতন DES-কে আরও শক্তিশালী করার একটি পদ্ধতি, যেখানে একই তথ্যকে তিনবার এনক্রিপ্ট করা হয়। যদিও এটি এখন AES-এর তুলনায় ধীরগতির।

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

****১। ব্লকচেইন (Blockchain) কী?**

উত্তর : ব্লকচেইন হলো তথ্য সংরক্ষণের একটি আধুনিক ও অত্যন্ত নিরাপদ পদ্ধতি। সহজ কথায়, এটি একটি ডিজিটাল লেজার বা হিসাবরক্ষণ বই, যেখানে তথ্যগুলো একের পর এক ব্লকের মতো জমা হয় এবং একটি শক্তিশালী চেইন বা শিকল দিয়ে একে অপরের সাথে যুক্ত থাকে।

**** ২। ব্লকচেইন মাইনিং (Blockchain Mining) কী?** বাকাশির্বো- ২০২৫

উত্তর : ব্লকচেইন মাইনিং হলো এমন একটি প্রক্রিয়া যার মাধ্যমে ব্লকচেইন নেটওয়ার্কে নতুন লেনদেনগুলো যাচাই করা হয় এবং সেগুলোকে নতুন একটি 'ব্লক' হিসেবে চেইনে যুক্ত করা হয়। যারা এই কাজটি করেন, তাদের বলা হয় 'মাইনার' (Miner).

*** ৩। PoW ও PoS কী ?**

উত্তর : **PoW :** PoW-এর পূর্ণরূপ হলো Proof of Work (প্রুফ অফ ওয়ার্ক)। এটি ব্লকচেইন নেটওয়ার্কে লেনদেন যাচাই করার এবং নতুন ব্লক তৈরি করার সবচেয়ে পুরনো ও নিরাপদ একটি গাণিতিক পদ্ধতি।

PoS : PoS-এর পূর্ণরূপ হলো Proof of Stake (প্রুফ অফ স্টেক)। এটি ব্লকচেইন নেটওয়ার্কে লেনদেন যাচাই করার এবং নতুন ব্লক তৈরি করার একটি আধুনিক, দ্রুত এবং পরিবেশবান্ধব পদ্ধতি। এখানে লেনদেন যাচাই করার ক্ষমতা কম্পিউটারের শক্তির ওপর নির্ভর করে না, বরং কার কাছে কত বেশি ডিজিটাল কয়েন জমা (Stake) আছে, তার ওপর নির্ভর করে।

SOS**সংক্ষিপ্ত প্রশ্নোত্তর :**

*** ১। ব্লকচেইনের মূল বৈশিষ্ট্যগুলো লেখ।

উত্তর : ব্লকচেইনের অসংখ্য বৈশিষ্ট্যের মধ্যে অখণ্ডতা (Integrity), স্বচ্ছতা (Transparency) এবং নিরাপত্তা (Security) হলো এর প্রধান তিনটি স্তম্ভ।

১. অখণ্ডতা (Integrity) : ব্লকচেইনের অখণ্ডতা বলতে বোঝায় যে, একবার কোনো তথ্য এতে লিপিবদ্ধ হলে তা পরিবর্তন বা বিকৃত করা অসম্ভব।

২. স্বচ্ছতা (Transparency) : ব্লকচেইন একটি উন্মুক্ত বা পাবলিক লেজার (Public Ledger) হওয়ার কারণে এর কার্যক্রম সবার কাছে পরিষ্কার থাকে।

৩. নিরাপত্তা (Security) : ব্লকচেইনের নিরাপত্তা ব্যবস্থা অত্যন্ত শক্তিশালী এবং আধুনিক ক্রিপ্টোগ্রাফির ওপর ভিত্তি করে তৈরি।

SOS**রচনামূলক প্রশ্নোত্তর :**

*** ১। ব্লকচেইন প্রযুক্তির অ্যাপ্লিকেশন ফিল্ডগুলোর বর্ণনা দাও।

বাকাশিবো- ২০২৫

উত্তর : ব্লকচেইন প্রযুক্তির ব্যবহার এখন আর শুধু বিটকয়েন বা ক্রিপ্টোকারেন্সির মধ্যে সীমাবদ্ধ নেই। এর নিরাপত্তা, স্বচ্ছতা এবং বিকেন্দ্রীভূত বৈশিষ্ট্যের কারণে এটি বিভিন্ন শিল্পক্ষেত্রে বৈপ্লবিক পরিবর্তন আনছে।

নিচে ব্লকচেইন প্রযুক্তির প্রধান অ্যাপ্লিকেশন ফিল্ড বা প্রয়োগক্ষেত্রগুলো বর্ণনা করা হলোঃ

১. ব্যাংকিং ও আর্থিক সেবা (FinTech) : ব্লকচেইনের সবচেয়ে বড় ব্যবহার হচ্ছে আর্থিক খাতে। এটি প্রথাগত ব্যাংকিং ব্যবস্থার মধ্যস্থতাকারী বা থার্ড পার্টি ছাড়াই দ্রুত লেনদেন নিশ্চিত করে।

সুবিধা : আন্তর্জাতিক টাকা আদান-প্রদানে খরচ কমায় এবং সময় বাঁচায়।
24/7 লেনদেন করা সম্ভব।

উদাহরণ : ক্রিপ্টোকারেন্সি এবং ক্রস-বর্ডার পেমেন্ট সিস্টেম।

২. স্মার্ট কন্ট্রাক্ট (Smart Contracts) : এটি হলো ব্লকচেইনে সংরক্ষিত এক ধরনের স্বয়ংক্রিয় ডিজিটাল চুক্তি। চুক্তির শর্ত পূরণ হওয়া মাত্রই এটি নিজে নিজে কার্যকর হয়।

সুবিধা : আইনি জটিলতা ও উকিলের প্রয়োজনীয়তা কমে যায়।

ব্যবহার : রিয়েল এস্টেট কেনাবেচা বা বীমা (Insurance) দাবিতে এটি ব্যবহৃত হয়।

৩. সাপ্লাই চেইন ম্যানেজমেন্ট (Supply Chain) : কোনো পণ্য কাঁচামাল থেকে শুরু করে ক্রেতার হাতে পৌঁছানো পর্যন্ত প্রতিটি ধাপ ব্লকচেইনে রেকর্ড করা যায়।

সুবিধা : পণ্যের আসল উৎস বা কোয়ালিটি যাচাই করা সহজ হয় এবং জালিয়াতি রোধ করা যায়।

ব্যবহার : খাদ্য নিরাপত্তা এবং বিলাসবহুল পণ্যের সত্যতা যাচাই।

৪. স্বাস্থ্যসেবা (Healthcare) : রোগীদের ব্যক্তিগত মেডিকেল রিপোর্ট এবং ডাটা ব্লকচেইনে নিরাপদে সংরক্ষণ করা যায়।

সুবিধা : বিভিন্ন হাসপাতালের ডাক্তাররা অনুমতি সাপেক্ষে দ্রুত রোগীর নির্ভুল রিপোর্ট দেখতে পারেন এবং ডাটা হ্যাক হওয়ার ভয় থাকে না।

৫. ভোটিং সিস্টেম (E-voting) : ব্লকচেইন ব্যবহার করে একটি জালিয়াতিমুক্ত এবং স্বচ্ছ নির্বাচন ব্যবস্থা তৈরি করা সম্ভব।

সুবিধা : একবার ভোট দিলে তা আর পরিবর্তন করা যায় না এবং গণনায় কোনো ভুল হওয়ার সুযোগ থাকে না।

৬. রিয়েল এস্টেট (Real Estate) : জমির মালিকানা রেকর্ড এবং হস্তান্তরের জন্য ব্লকচেইন আদর্শ। এটি কাগজপত্রের জালিয়াতি বন্ধ করে এবং জমি কেনাবেচাকে আরও সহজতর করে।

**** ২। ব্লকচেইন মাইনিং প্রক্রিয়া আলোচনা কর।**

উত্তর : নিচে ব্লকচেইন মাইনিং প্রক্রিয়ার ধাপগুলো বিস্তারিত আলোচনা করা হলোঃ

i) লেনদেনের অনুরোধ (Transaction Request) : যখন কোনো ব্যবহারকারী ডিজিটাল কারেন্সি বা তথ্য পাঠাতে চান, তখন সেই লেনদেনটি নেটওয়ার্কে একটি অনুরোধ হিসেবে ছড়িয়ে পড়ে। এই অপ্রমাণিত লেনদেনগুলো একটি অস্থায়ী জায়গায় জমা হয়, যাকে Mempool বলা হয়।

ii) লেনদেন সংগ্রহ ও যাচাই মাইনাররা নেটওয়ার্ক থেকে অনেকগুলো লেনদেন সংগ্রহ করে একটি ব্লকের আকার দেওয়ার চেষ্টা করেন। তারা যাচাই করেন যে প্রেরকের কাছে পর্যাপ্ত ব্যালেন্স আছে কি না এবং লেনদেনের ডিজিটাল স্বাক্ষরটি সঠিক কি না।

iii) গাণিতিক ধাঁধা সমাধান (The Puzzle) : এটি মাইনিংয়ের সবচেয়ে কঠিন অংশ। প্রতিটি ব্লকের জন্য একটি নির্দিষ্ট 'হ্যাশ' কোড খুঁজে পেতে হয়। মাইনারদের কম্পিউটার একটি জটিল গাণিতিক সমস্যা (যাকে Nonce খুঁজে বের করা বলা হয়) সমাধান করার চেষ্টা করে। এই ধাঁধাটি এমন যে এটি সমাধান করতে প্রচুর কম্পিউটিং শক্তির প্রয়োজন হয়।

iv) প্রুফ অফ ওয়ার্ক (Proof of Work) : যে মাইনার বা মাইনিং পুল সবার আগে সেই গাণিতিক ধাঁধাটি সমাধান করতে পারে, সে বাকি নেটওয়ার্ককে জানিয়ে দেয় যে সে সমাধান পেয়ে গেছে। এই প্রমাণটিকেই

বলা হয় Proof of Work। অন্য মাইনাররা দ্রুত এটি পরীক্ষা করে দেখে এবং সম্মতি দেয়।

v) চেইনে ব্লক যুক্ত করা একবার অধিকাংশ মাইনার সম্মতি দিলে, সেই নতুন ব্লকটি স্থায়ীভাবে আগের ব্লকের সাথে যুক্ত হয়ে যায়। এতে প্রতিটি ব্লকে তার আগের ব্লকের একটি 'হ্যাশ' থাকে, যার ফলে একটি মজবুত শিকল বা চেইন তৈরি হয়।

vi) মাইনিং পুরস্কার (Mining Reward) : সফলভাবে ব্লকটি চেইনে যুক্ত করার পর, ওই মাইনার বা মাইনিং পুলকে পুরস্কার হিসেবে নতুন ক্রিপ্টোকারেন্সি (যেমন বিটকয়েন) এবং ওই ব্লকের সব লেনদেনের ফি (Transaction Fee) প্রদান করা হয়। এটিই মাইনারদের কাজ চালিয়ে যেতে উৎসাহিত করে।

অধ্যায়-৬

ডিজিটাল ফরেনসিকস

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

**** ১। ডিজিটাল অপরাধ (Digital Crime) বলতে কী বুঝ?**

উত্তর : ডিজিটাল অপরাধ হলো এমন এক ধরনের অপরাধমূলক কর্মকাণ্ড যেখানে কম্পিউটার, স্মার্টফোন বা অন্য কোনো ডিজিটাল ডিভাইস এবং ইন্টারনেটকে প্রধান হাতিয়ার হিসেবে ব্যবহার করা হয়। ইহা সাইবার অপরাধ (Cybercrime) নামেও পরিচিত।

***** ২। ফাইল কার্ভিং কী?**

বাকাশির্বো- ২০২৫

উত্তর : ফাইল কার্ভিং (File Carving) হলো ডিজিটাল ফরেনসিকের একটি অত্যন্ত শক্তিশালী কৌশল, যার মাধ্যমে কোনো স্টোরেজ ডিভাইস (যেমনঃ হার্ড ডিস্ক, মেমরি কার্ড বা পেনড্রাইভ) থেকে ডিলিট হয়ে যাওয়া বা ক্ষতিগ্রস্ত ফাইল উদ্ধার করা হয়।

SOS

সংক্ষিপ্ত প্রশ্নোত্তর :

**** ১। ডিজিটাল ক্রাইমের শ্রেণিবিভাগ লেখ।**

উত্তর : অপরাধের প্রকৃতি এবং লক্ষ্যের ওপর ভিত্তি করে ডিজিটাল ক্রাইমকে প্রধানত তিনটি শ্রেণিতে ভাগ করা যায় যথা :

- i) কোনো নির্দিষ্ট ব্যক্তির বিরুদ্ধে অপরাধ : সাইবার বুলিং, হ্যাকিং, পরিচয় চুরি, সাইবার স্টকিং, মানহানি ইত্যাদি।
- ii) সম্পদের বিরুদ্ধে অপরাধ : অনলাইন জালিয়াতি, র‍্যানসামওয়্যার, সফটওয়্যার পাইরেসি, ইলেকট্রনিক ফাউ ড্রাসফার জালিয়াতি ইত্যাদি।
- iii) প্রতিষ্ঠান বা রাষ্ট্রের বিরুদ্ধে অপরাধ : সাইবার টেরোরিজম, সাইবার যুদ্ধ, ভুয়া সংবাদ প্রচার ইত্যাদি।

*** ২। ফরেনসিক এক্সপার্ট এর কাজ লেখ।

বাকাশিবো- ২০২৪'পরি

উত্তর : ফরেনসিক এক্সপার্টের প্রধান কাজগুলো নিম্নরূপ :

- i) অপরাধস্থল থেকে আলামত সংগ্রহ (Evidence Collection)
- ii) ডিএনএ বিশ্লেষণ (DNA Analysis)
- iii) টক্সিকোলজি বা বিষবিদ্যা (Toxicology)
- iv) ব্যালিস্টিক পরীক্ষা (Ballistics)
- v) আঙুলের ছাপ বিশ্লেষণ (Fingerprint Analysis)
- vi) ডিজিটাল ফরেনসিক (Digital Forensics)
- vii) দলিলাদি ও হস্তাক্ষর যাচাই (Document Examination)
- viii) ময়নাতদন্তে সহায়তা
- ix) আদালতে সাক্ষ্য প্রদান (Expert Witness)

*** ৩। FAT এবং NTFS এর মধ্যে পার্থক্য লেখ। বাকশির্বো- ২০২৫

উত্তর : FAT এবং NTFS এর মধ্যে পার্থক্য নিম্নরূপ :

বৈশিষ্ট্য	FAT	NTFS
১. পূর্ণরূপ	File Allocation Table	New Technology File Szstem
২. নিরাপত্তা	এতে ফাইল লেভেল সিকিউরিটি বা পারমিশন নেই।	এতে শক্তিশালী ফাইল এনক্রিপশন ও পারমিশন সিস্টেম আছে।
৩. ফাইলের আকার	সর্বোচ্চ 4 জিবি (4 এই) সাইজের একক ফাইল রাখা যায়।	ফাইলের আকারের কোনো ব্যবহারিক সীমা নেই (বিশাল ফাইল রাখা যায়)।
৪. ড্রাইভের আকার	সর্বোচ্চ 32 জিবি (উইন্ডোজ লিমিট) থেকে 2 টিবি পর্যন্ত।	256 টিবি (Terabyte) পর্যন্ত বড় ড্রাইভ সাপোর্ট করে।
৫. ডেটা রিকভারি	এতে কোনো 'জার্নালিং' নেই, তাই সিস্টেম ক্র্যাশ করলে ডেটা হারানোর ভয় থাকে।	এটি একটি 'জার্নালিং' ফাইল সিস্টেম, তাই ডেটা সহজে পুনরুদ্ধার করা যায়।
৬. কম্প্রেশন	ফাইল বা ফোল্ডার কম্প্রেস (চাপিয়ে রাখা) করার সুবিধা নেই।	ফাইল বা ফোল্ডার কম্প্রেস করে ডিস্কের জায়গা বাঁচানো যায়।

৭. গতি	ছোট ড্রাইভের ক্ষেত্রে দ্রুত কাজ করে।	বড় ড্রাইভ বা হার্ড ডিস্কের ক্ষেত্রে অনেক বেশি দ্রুত ও কার্যকর।
৮. ব্যবহারের ক্ষেত্র	ইউএসবি পেনড্রাইভ, এসডি কার্ড এবং পুরনো অপারেটিং সিস্টেমে বেশি ব্যবহৃত হয়।	আধুনিক উইন্ডোজ (7, 10, 11) এবং ইন্টারনাল হার্ড ড্রাইভের জন্য আদর্শ।

SOS**রচনামূলক প্রশ্নোত্তর :**

**** ১।** ডিজিটাল ফরেনসিক ইনভেস্টিগেশন প্রক্রিয়া বর্ণনা কর।

উত্তর : নিচে ডিজিটাল ফরেনসিক ইনভেস্টিগেশনের প্রধান ধাপগুলো বর্ণনা করা হলোঃ

i) প্রস্তুতি (Preparation) : তদন্ত শুরু করার আগে প্রয়োজনীয় প্রস্তুতি নিতে হয়। এর মধ্যে রয়েছে উপযুক্ত ফরেনসিক টুলস (Software & Hardware) নিশ্চিত করা, আইনি অনুমতি বা সার্চ ওয়ারেন্ট সংগ্রহ করা এবং তদন্তকারী দলের সুরক্ষা নিশ্চিত করা।

ii) আলামত শনাক্তকরণ ও জব্দকরণ (Identification & Seizure) : ঘটনাস্থলে পৌঁছে তদন্তকারী দল অপরাধের সাথে সংশ্লিষ্ট ডিজিটাল ডিভাইসগুলো শনাক্ত করে।

ডিভাইস জব্দ : কম্পিউটার, ল্যাপটপ, মোবাইল ফোন, হার্ড ড্রাইভ, পেনড্রাইভ ইত্যাদি জব্দ করা।

লাইভ রেসপন্স : যদি ডিভাইসটি চালু থাকে, তবে হুট করে বন্ধ না করে তাৎক্ষণিক 'র‍্যাম' (RAM) থেকে অস্থায়ী তথ্য সংগ্রহ করা হয়।

iii) আলামত সংরক্ষণ ও আইসোলেশন (Preservation) : ডিজিটাল তথ্য যেন কেউ দূর থেকে পরিবর্তন বা মুছে ফেলতে না পারে সেজন্য ডিভাইসটিকে নেটওয়ার্ক বিচ্ছিন্ন করা হয়। মোবাইলের ক্ষেত্রে Faraday Bag ব্যবহার করা হয় যাতে সিগন্যাল আদান-প্রদান বন্ধ থাকে। মূল আলামত অক্ষত রাখতে এর একটি ছব্ব কপি বা Forensic Image তৈরি করা হয়।

iv) তথ্য উদ্ধার ও বিশ্লেষণ (Analysis) : এটি তদন্তের সবচেয়ে গুরুত্বপূর্ণ অংশ। ফরেনসিক বিশেষজ্ঞ এই ধাপে বিভিন্ন বিশেষায়িত সফটওয়্যার (যেমনঃ EnCase, FTK) ব্যবহার করেন।

মুছে ফেলা তথ্য উদ্ধার : ডিলিট করা ফাইল, মেসেজ বা ছবি পুনরুদ্ধার করা।

লুকানো তথ্য খোঁজা : হিডেন ফাইল বা এনক্রিপ্ট করা ফোল্ডার থেকে তথ্য বের করা।

টাইমলাইন অ্যানালাইসিস : অপরাধটি কখন সংঘটিত হয়েছিল এবং সেই সময় ডিভাইসে কী কী কাজ করা হয়েছিল তা বের করা।

v) মূল্যায়ন ও ব্যাখ্যা (Examination) : উদ্ধারকৃত তথ্যের মধ্যে কোনগুলো অপরাধের সাথে সরাসরি যুক্ত তা বাছাই করা হয়। অপ্রাসঙ্গিক তথ্য বাদ দিয়ে কেবল শক্তিশালী প্রমাণগুলো একত্র করা হয়।

vi) প্রতিবেদন তৈরি (Reporting) : তদন্তের প্রতিটি ধাপের বিস্তারিত বর্ণনা দিয়ে একটি চূড়ান্ত প্রতিবেদন তৈরি করা হয়। এতে প্রমাণ সংগ্রহের সময়, পদ্ধতি এবং প্রাপ্ত ফলাফলের স্পষ্ট উল্লেখ থাকে। এই প্রতিবেদনটি এমনভাবে তৈরি করা হয় যেন একজন সাধারণ মানুষ বা বিচারকও তা বুঝতে পারেন।

vii) আদালতে উপস্থাপন (Presentation) : সবশেষে বিশেষজ্ঞ তদন্তকারী আদালতে উপস্থিত হয়ে প্রমাণগুলো উপস্থাপন করেন। প্রমাণের সত্যতা প্রমাণের জন্য 'Chain of Custody' বা প্রমাণের হস্তান্তরের ধারাবাহিকতা বজায় রাখা বাধ্যতামূলক, অন্যথায় আদালত তা গ্রহণ করবে না।

**** ২। বিভিন্ন প্রকার ফরেনসিক টেকনিকসমূহের বর্ণনা দাও।**

উত্তর : বিভিন্ন প্রকার ফরেনসিক টেকনিকসমূহের বর্ণনা নিম্নে দেওয়া হলো :

১. নেটওয়ার্ক লগ ফরেনসিক (Network Log Forensics) : নেটওয়ার্ক লগ ফরেনসিক হলো ডিজিটাল ফরেনসিকের একটি বিশেষ শাখা, যেখানে কোনো নেটওয়ার্কের নিরাপত্তা বিঘ্নিত হলে বা কোনো অপরাধ সংঘটিত হলে নেটওয়ার্কের ভেতরে থাকা বিভিন্ন ডিভাইসের 'লগ ফাইল' (Log Files) বিশ্লেষণ করে অপরাধের উৎস এবং ধরন খুঁজে বের করা হয়। নেটওয়ার্ক লগ ফরেনসিকের মূল উৎসসমূহ (Sources of

Logs) : তদন্তের সময় ফরেনসিক বিশেষজ্ঞরা সাধারণত নিচের জায়গাগুলো থেকে লগ সংগ্রহ করেন।

i) ফায়ারওয়াল লগ (Firewall Logs) : কোন আইপি (IP) অ্যাড্রেস থেকে নেটওয়ার্কে ঢোকার চেষ্টা করা হয়েছে এবং কোন রিকোয়েস্ট ব্লক করা হয়েছে তা এখান থেকে জানা যায়।

ii) সার্ভার লগ (Server Logs) : ওয়েব সার্ভার বা ডাটাবেস সার্ভারে লগ-ইন করেছে এবং কোন ফাইল পরিবর্তন করেছে তার তথ্য এখানে থাকে।

iii) রাউটার ও সুইচ লগ (Router/Switch Logs) : নেটওয়ার্ক ট্রাফিক কোন পথ দিয়ে প্রবাহিত হয়েছে তার রেকর্ড থাকে।

iv) IDS/IPS লগ : নেটওয়ার্কে কোনো অনুপ্রবেশের (Intrusion) চেষ্টা করা হয়েছিল কি না তার অ্যালার্ট এখান থেকে পাওয়া যায়।

২. ক্লাউড ফরেনসিক প্রযুক্তি : ক্লাউড ফরেনসিক (Cloud Forensics) হলো ডিজিটাল ফরেনসিকের একটি উন্নত শাখা, যা ক্লাউড কম্পিউটিং পরিবেশে (যেমন : Google Drive, iCloud, AWS ev Azure) সংঘটিত অপরাধের ডিজিটাল আলামত শনাক্তকরণ, সংগ্রহ এবং বিশ্লেষণ নিয়ে কাজ করে।

৩। ক্লাউড ফরেনসিক তদন্তের ধাপসমূহ :

i) আইডেন্টিফিকেশন : কোন ক্লাউড সার্ভিস (SaaS, PaaS ev IaaS) অপরাধে ব্যবহৃত হয়েছে তা চিহ্নিত করা।

ii) প্রমাণ সংগ্রহ : ক্লাউড স্টোরেজ থেকে ফাইল, ইমেজ এবং অ্যাক্সেস লগ সংগ্রহ করা।

iii) বিচ্ছিন্নকরণ (Isolation) : সন্দেহভাজন অ্যাকাউন্টটি লক বা আইসোলেট করা যাতে অপরাধী ডেটা মুছে ফেলতে না পারে।

iv) বিশ্লেষণ : বিশেষায়িত টুলস ব্যবহার করে সংগৃহীত ডেটা থেকে অপরাধের যোগসূত্র বের করা।

v) রিপোর্টিং : প্রাপ্ত তথ্যের ভিত্তিতে একটি আইনি প্রতিবেদন তৈরি করা।

৪. ডাটাবেস ফরেনসিক প্রযুক্তি : ডাটাবেস ফরেনসিক (Database Forensics) হলো ডিজিটাল ফরেনসিকের একটি বিশেষ শাখা যা ডাটাবেস এবং এর মধ্যে থাকা ডেটা বা মেটাডেটার ওপর পরিচালিত অপরাধ তদন্ত নিয়ে কাজ করে। এর মূল লক্ষ্য হলো ডাটাবেসে অননুমোদিত প্রবেশ, ডেটা পরিবর্তন, মুছে ফেলা বা তথ্য চুরির ঘটনাগুলো বৈজ্ঞানিকভাবে বিশ্লেষণ করা এবং অপরাধীকে শনাক্ত করা।

৫। ডাটাবেস ফরেনসিকের প্রধান কাজসমূহ :

i) ডেটা রিকভারি : ডাটাবেস থেকে কোনো তথ্য মুছে ফেলা হলে ফরেনসিক টুলসের মাধ্যমে তা পুনরুদ্ধার করা।

ii) অডিট ট্রেইল বিশ্লেষণ : ডাটাবেস কে, কখন এবং কোন আইপি (IP) থেকে অ্যাক্সেস করেছে তার লগ ফাইল বা রেকর্ড পরীক্ষা করা।

iii) ভলটাইল ডেটা সংগ্রহ : ডাটাবেস সার্ভারের র‍্যাম (RAM)-এ থাকা অস্থায়ী তথ্যগুলো সংগ্রহ করা, যা সার্ভার বন্ধ করলে মুছে যেতে পারে।

iv) ট্রানজেকশন লগ পরীক্ষা : প্রতিটি ডেটা এনট্রি বা পরিবর্তনের একটি ইতিহাস থাকে, যা পরীক্ষা করে জালিয়াতির ধরন বোঝা যায়।

৬। ম্যালওয়্যার ফরেনসিক প্রযুক্তি : ম্যালওয়্যার ফরেনসিক (Malware Forensics) হলো ডিজিটাল ফরেনসিকের একটি শাখা যা ক্ষতিকারক সফটওয়্যার বা ম্যালওয়্যার (যেমন : ভাইরাস, ওয়ার্ম, ট্রোজান, র্যানসামওয়্যার) শনাক্তকরণ, বিশ্লেষণ এবং এর প্রভাব মূল্যায়ন নিয়ে কাজ করে।

তদন্তের ধাপসমূহ :

i) আইসোলেশন : আক্রান্ত কম্পিউটারটিকে নেটওয়ার্ক থেকে বিচ্ছিন্ন করা যাতে অন্য ডিভাইসে সংক্রমণ না ছড়ায়।

ii) মেমোরি ফরেনসিক : কম্পিউটারের র‍্যাম (RAM) থেকে ম্যালওয়্যারের র‍্যনিং প্রসেসগুলোর ইমেজ বা কপি সংগ্রহ করা।

iii) কোড অ্যানালাইসিস : ম্যালওয়্যারের সোর্স কোড বিশ্লেষণ করে এর লুকানো কমান্ডগুলো খুঁজে বের করা।

iv) রিপোর্টিং : ম্যালওয়্যারটি কতটুকু শক্তিশালী এবং কী কী ক্ষতি করেছে তার একটি বিস্তারিত প্রতিবেদন তৈরি করা।

৭। মোবাইল ফরেনসিক প্রযুক্তি : মোবাইল ফরেনসিক (Mobile Forensics) হলো ডিজিটাল ফরেনসিকের একটি বিশেষ শাখা যা মোবাইল ফোন, স্মার্টফোন, ট্যাবলেট এবং সিম কার্ড থেকে ডিজিটাল আলামত বা তথ্য পুনরুদ্ধার ও বিশ্লেষণ নিয়ে কাজ করে। বর্তমান যুগে

মানুষ তার বেশিরভাগ সময় মোবাইলে কাটায় বলে অপরাধ তদন্তে এই প্রযুক্তিটি সবচেয়ে বেশি ব্যবহৃত ও কার্যকর।

মোবাইল ফরেনসিকের মাধ্যমে যেসব তথ্য পাওয়া যায় :

- i) কল হিস্ট্রি ও কন্টাক্ট : ইনকামিং, আউটগোয়িং এবং মিসড কলসহ ফোনবুকের সমস্ত তথ্য।
- ii) মেসেজ ও চ্যাট : সাধারণ এসএমএস (SMS) ছাড়াও হোয়াটসঅ্যাপ, মেসেঞ্জার বা টেলিগ্রামের মতো অ্যাপের চ্যাট হিস্ট্রি।
- iii) লোকেশন ডেটা : জিপিএস (GPS) হিস্ট্রি এবং গুগল ম্যাপের তথ্য ব্যবহার করে অপরাধী কোন সময়ে কোথায় ছিল তা বের করা যায়।
- iv) মিডিয়া ফাইল : মোবাইলে থাকা ছবি, ভিডিও এবং অডিও রেকর্ডিং। এমনকি মুছে ফেলা বা হাইড করা ফাইলও উদ্ধার করা সম্ভব।
- v) ব্রাউজিং হিস্ট্রি : ইন্টারনেটে কোন কোন ওয়েবসাইট দেখা হয়েছে এবং কী কী সার্চ করা হয়েছে তার রেকর্ড।

*** ৩। ফরেনসিক ইনভেস্টিগেশন রিপোর্টের বিষয়াদি আলোচনা কর।

বাকশিবো- ২০২৫

উত্তর : একটি আদর্শ ফরেনসিক ইনভেস্টিগেশন রিপোর্টে সাধারণত নিচের বিষয়গুলো অন্তর্ভুক্ত থাকে :

i) রিপোর্টের সারসংক্ষেপ (Executive Summary) :

এটি রিপোর্টের শুরুতেই থাকে যেখানে পুরো তদন্তের একটি সংক্ষিপ্ত চিত্র তুলে ধরা হয়। যারা প্রযুক্তিগতভাবে দক্ষ নন (যেমন বিচারক বা

আইনজীবী), তাদের জন্য এটি অত্যন্ত গুরুত্বপূর্ণ। এতে অপরাধের ধরন, মূল ফলাফল এবং তদন্তকারীর মতামত সংক্ষেপে লেখা থাকে।

ii) তদন্তের উদ্দেশ্য ও পরিধি (Objectives and Scope) :

এখানে কেন এই তদন্ত করা হচ্ছে এবং কোন সীমানা পর্যন্ত তদন্ত চলবে তা স্পষ্ট করা হয়। যেমন : একটি নির্দিষ্ট কম্পিউটার থেকে তথ্য চুরি হয়েছে কি না তা বের করা এবং গত তিন মাসের তথ্য বিশ্লেষণ করা।

iii) জন্মকৃত আলামতের তালিকা (Evidence Details) :

তদন্তের জন্য যেসব ডিভাইস বা তথ্য সংগ্রহ করা হয়েছে তার বিস্তারিত বিবরণ এখানে থাকে। ডিভাইসের নাম, মডেল এবং সিরিয়াল নম্বর। হার্ড ড্রাইভ বা মেমোরির আকার। আলামতটি কোথা থেকে এবং কার কাছ থেকে সংগ্রহ করা হয়েছে। হ্যাশ ভ্যালু (Hash Value) : ডেটার অখণ্ডতা প্রমাণের জন্য এটি ডিজিটাল স্বাক্ষরের মতো কাজ করে।

iv) তদন্তের পদ্ধতি ও ব্যবহৃত সরঞ্জাম (Methodology and Tools) :

তদন্তের সময় কোন কোন টেকনিক এবং সফটওয়্যার ব্যবহার করা হয়েছে তার বর্ণনা এখানে দিতে হয়। যেমন- EnCase, FTK ev Cellebrite-এর ব্যবহার। এটি গুরুত্বপূর্ণ কারণ প্রতিপক্ষ চাইলে টুলসগুলোর কার্যকারিতা নিয়ে প্রশ্ন তুলতে পারে।

v) ধাপভিত্তিক বিশ্লেষণ (Step-by-Step Analysis) :

এটি রিপোর্টের প্রধান অংশ। এখানে তদন্তের প্রতিটি ধাপ বিস্তারিতভাবে লেখা থাকে। কীভাবে এনক্রিপশন ভাঙা হয়েছে। মুছে ফেলা ফাইল কীভাবে

উদ্ধার করা হয়েছে। ইন্টারনেটে ব্রাউজিং বা যোগাযোগের টাইমলাইন বিশ্লেষণ।

vi) প্রমাণের চেইন অফ কাস্টডি (Chain of Custody) :

আলামতটি জব্দ করার সময় থেকে ল্যাবরেটরিতে আনা এবং পরীক্ষা করা পর্যন্ত কার কার হাতে ছিল, তার একটি নির্ভুল রেকর্ড। এটি প্রমাণ করে যে আলামতটি কেউ বাইরে থেকে পরিবর্তন করার সুযোগ পায়নি।

vii) মূল ফলাফল (Key Findings) :

তদন্তের শেষে কী পাওয়া গেল তা এখানে পয়েন্ট আকারে লেখা হয়। যেমনঃ অপরাধীর ইমেইল থেকে কোনো গোপন নথি পাঠানোর প্রমাণ পাওয়া গেছে কি না বা হ্যাকিংয়ের সময় কোন আইপি (IP) ব্যবহার করা হয়েছিল।

viii) উপসংহার ও সুপারিশ (Conclusion and Recommendations) :

তদন্তকারীর বিশেষজ্ঞ মতামত এখানে প্রদান করা হয়। এছাড়া ভবিষ্যতে এই ধরনের ডিজিটাল ক্রাইম রোধে প্রতিষ্ঠানটি কী কী ব্যবস্থা নিতে পারে, তার কিছু পরামর্শ বা সুপারিশ দেওয়া হয়।

ix) পরিশিষ্ট ও সহায়ক প্রমাণ (Appendix) :

রিপোর্টের শেষে প্রয়োজনীয় স্ক্রিনশট, লগ ফাইলের কপি বা বিশাল বড় কোনো ডেটা লিস্ট সংযুক্তি হিসেবে দেওয়া হয় যা মূল রিপোর্টের বক্তব্যকে জোরালো করে।

অধ্যায়-৭

ইনসিডেন্ট রেসপন্স এবং ডিজাস্টার রিকভারি

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

**** ১। ইনসিডেন্ট হ্যান্ডলিং বলতে কি বুঝায়?**

উত্তর : কোনো সাইবার আক্রমণ বা টেকনিক্যাল ত্রুটি ঘটার পর সেটি থেকে সিস্টেমকে রক্ষা করা, ক্ষতির পরিমাণ কমানো এবং পরিস্থিতি স্বাভাবিক অবস্থায় ফিরিয়ে আনার সার্বিক কার্যক্রমকেই ইনসিডেন্ট হ্যান্ডলিং বলা হয়।

**** ২। ডিজাস্টার রিকভারি কী?**

উত্তর : বড় কোনো বিপদে সিস্টেম বন্ধ হয়ে গেলে কীভাবে দ্রুততম সময়ে সবকিছু আগের মতো স্বাভাবিক অবস্থায় ফিরিয়ে আনা যাবে, সেই পরিকল্পনাই হলো ডিজাস্টার রিকভারি।

***** ৩। সাইবার আক্রমণ বলতে কী বুঝ?**

বাকাশিবো- ২০২৫

উত্তর : কোনো অসৎ উদ্দেশ্যে (যেমন: তথ্য চুরি, অর্থ আত্মসাৎ বা সিস্টেমের ক্ষতি করা) যখন হ্যাকাররা ডিজিটাল প্রযুক্তির মাধ্যমে কারো ব্যক্তিগত বা প্রাতিষ্ঠানিক কম্পিউটার সিস্টেমে আঘাত হানে, তখনই তাকে সাইবার আক্রমণ বলা হয়।

SOS**সংক্ষিপ্ত প্রশ্নোত্তর :**

**** ১।** ডিজাস্টার রিকভারি স্ট্রাটেজি ব্যাখ্যা কর।

উত্তর : ডিজাস্টার রিকভারি স্ট্রাটেজি (Disaster Recovery Strategy) হলো এমন একটি সুপরিকল্পিত কৌশল, যা কোনো বড় ধরনের বিপর্যয়ের (যেমন: সাইবার আক্রমণ, হার্ডওয়্যার ধ্বংস বা প্রাকৃতিক দুর্যোগ) পর একটি প্রতিষ্ঠানের তথ্যপ্রযুক্তি (IT) সিস্টেম এবং ডেটা দ্রুত পুনরুদ্ধারের জন্য গ্রহণ করা হয়।

নিচে প্রধান প্রধান ডিজাস্টার রিকভারি স্ট্রাটেজিগুলো আলোচনা করা হলো :

i) ডেটা ব্যাকআপ স্ট্রাটেজি (Data Backup Strategy) :

এটি সবচেয়ে মৌলিক কৌশল। এখানে সমস্ত গুরুত্বপূর্ণ ডেটা একটি অফ-সাইট লোকেশন বা ক্লাউডে কপি করে রাখা হয়। অফ-সাইট ব্যাকআপঃ অফিসের মূল সার্ভার থেকে দূরে অন্য কোনো শহরে ডেটা রাখা।

ক্লাউড ব্যাকআপ : AWS, Azure ev Google Cloud-এ তথ্য সংরক্ষণ করা। এটি বর্তমানে সবচেয়ে জনপ্রিয় ও নিরাপদ।

ii) রিপ্লিকেশন স্ট্রাটেজি (Replication Strategy) :

এই পদ্ধতিতে ডেটা কেবল ব্যাকআপ নেওয়া হয় না, বরং মূল সার্ভারের একটি হুবহু কপি অন্য একটি সার্ভারে সবসময় আপডেট হতে থাকে।

সিনক্রোনাস রিপ্লিকেশন : মূল সার্ভারে তথ্য আসার সাথে সাথেই সেকেন্ডারি

সার্ভারে তা কপি হয়ে যায়। এতে ডেটা হারানোর ভয় একদম থাকে না (RPO শূন্য)।

অ্যাসিনক্রোনাস রিপ্লিকেশন : নির্দিষ্ট সময় অন্তর অন্তর ডেটা কপি হয়।

iii) সাইট-ভিত্তিক রিকভারি স্ট্রাটেজি (Site-based Recovery) :

বিপর্যয়ের পর কার্যক্রম পুনরায় শুরু করার জন্য প্রতিষ্ঠানের একটি বিকল্প ব্যবস্থা থাকতে হয়। এটি তিন প্রকারঃ

হট সাইট (Hot Site) : এটি মূল অফিসের একটি ছবছ কপি। এখানে সব হার্ডওয়্যার, সফটওয়্যার এবং আপ-টু-ডেট ডেটা সবসময় প্রস্তুত থাকে। মূল সার্ভার ডাউন হওয়ার কয়েক সেকেন্ড বা মিনিটের মধ্যে এটি চালু করা যায়।

ওয়ার্ম সাইট (Warm Site) : এখানে হার্ডওয়্যার এবং নেটওয়ার্ক কানেকশন থাকে, কিন্তু ডেটা পুরোপুরি আপডেট থাকে না। এটি সচল করতে কয়েক ঘণ্টা সময় লাগতে পারে।

কোল্ড সাইট (Cold Site) : এটি কেবল একটি খালি জায়গা যেখানে বিদ্যুৎ ও ইন্টারনেট থাকে। দুর্যোগের পর সব নতুন করে সেটআপ করতে হয়, যা বেশ সময়সাপেক্ষ (কয়েক দিন বা সপ্তাহ)।

iv) ডিআরএএস বা ক্লাউড-ভিত্তিক স্ট্রাটেজি (DRaaS - Disaster Recovery as a Service) :

এটি একটি আধুনিক প্রযুক্তি যেখানে তৃতীয় কোনো প্রতিষ্ঠান (Cloud Provider) আপনার পুরো আইটি সিস্টেমের একটি ভার্চুয়াল কপি তাদের

ক্লাউডে হোস্ট করে রাখে। দুর্যোগ ঘটলে তারা দ্রুত সেই ভার্চুয়াল সিস্টেমটি চালু করে দেয়।

v) ভার্চুয়ালাইজেশন (Virtualization) :

পুরো সার্ভারকে একটি ভার্চুয়াল ইমেজ বা ফাইল হিসেবে সেভ করে রাখা হয়। কোনো হার্ডওয়্যার বিকল হলে সেই ভার্চুয়াল ফাইলটিকে অন্য কোনো সুস্থ হার্ডওয়্যারে খুব দ্রুত লোড করে সার্ভিস সচল করা সম্ভব হয়।

**** ২। ডিজাস্টার রিকভারির ধাপসমূহ লেখ।**

উত্তর : ডিজাস্টার রিকভারির প্রধান ধাপসমূহ নিম্নরূপঃ

১. ঝুঁকি বিশ্লেষণ
২. গুরুত্বপূর্ণ ডেটা ও অ্যাপ্লিকেশন চিহ্নিতকরণ
৩. RTO এবং RPO নির্ধারণ
৪. ব্যাকআপ কৌশল নির্ধারণ
৫. দায়িত্ব ও টিম গঠন
৬. রিকভারি সাইট প্রস্তুতি
৭. ডিজাস্টার রিকভারি প্ল্যান তৈরি ও ডকুমেন্টেশন
৮. নিয়মিত পরীক্ষা ও মহড়া
৯. রক্ষণাবেক্ষণ ও আপডেট

SOS**রচনামূলক প্রশ্নোত্তর :**

**** ১।** ইনসিডেন্ট ইলিমেন্ট হ্যান্ডলিং প্রক্রিয়ার শ্রেণিবিভাগ লেখ।

উত্তর : নিচে ইনসিডেন্ট ইলিমেন্ট হ্যান্ডলিং প্রক্রিয়ার প্রধান শ্রেণিবিভাগগুলো আলোচনা করা হলোঃ

i) ম্যালওয়্যার ইনসিডেন্ট হ্যান্ডলিং (Malware Incident Handling) :

যখন কোনো সিস্টেমে ক্ষতিকারক সফটওয়্যার (ভাইরাস, ওয়ার্ম, ট্রোজান বা র্যানসামওয়্যার) প্রবেশ করে, তখন এই প্রক্রিয়ায় তা হ্যান্ডেল করা হয়।

মূল কাজ : ম্যালওয়্যারটি শনাক্ত করা, আক্রান্ত ডিভাইসকে নেটওয়ার্ক থেকে বিচ্ছিন্ন করা (Quarantine) এবং সিস্টেম ক্লিন করা।

ii) অননুমোদিত প্রবেশ বা অ্যাক্সেস হ্যান্ডলিং (Unauthorized Access) :

যদি কোনো ব্যক্তি অনুমতি ছাড়া কোনো সার্ভার, ডাটাবেস বা অ্যাকাউন্টে প্রবেশ করে, তবে এই প্রক্রিয়ায় তা মোকাবিলা করা হয়।

মূল কাজ : লগ ফাইল পরীক্ষা করা, হ্যাকারের আইপি (IP) ব্লক করা এবং তাৎক্ষণিকভাবে সব পাসওয়ার্ড ও এক্সেস কী পরিবর্তন করা।

iii) ডিনায়েল অফ সার্ভিস বা ডস অ্যাটাক হ্যান্ডলিং (DoS/DDoS Attack) :

যখন কোনো ওয়েবসাইট বা সার্ভারে অতিরিক্ত ট্রাফিক পাঠিয়ে সেটি ডাউন করে দেওয়া হয়।

মূল কাজ : ট্রাফিক ফিল্টার করা, আক্রমণকারী আইপি শনাক্ত করা এবং সিডিএন (CDN) বা ক্লাউড-ভিত্তিক সুরক্ষা ব্যবহার করে সেবা সচল রাখা।

iv) তথ্য চুরি বা ডেটা ব্রিচ হ্যান্ডলিং (Data Breach/Leakage) :
প্রতিষ্ঠানের গোপনীয় তথ্য (যেমনঃ ক্রেডিট কার্ড নম্বর বা ব্যক্তিগত তথ্য) বাইরে পাচার হয়ে গেলে এই শ্রেণিবিভাগের মাধ্যমে ব্যবস্থা নেওয়া হয়।

মূল কাজ : তথ্যের উৎস খুঁজে বের করা, ডেটা এনক্রিপশন চেক করা এবং আইনি পদক্ষেপ নেওয়া।

v) ফিশিং ও সোশ্যাল ইঞ্জিনিয়ারিং হ্যান্ডলিং (Phishing) :

ভুয়া ইমেইল বা মেসেজের মাধ্যমে ব্যবহারকারীকে প্রতারিত করে তথ্য হাতিয়ে নেওয়ার চেষ্টা করা হলে এই প্রক্রিয়ায় তা মোকাবিলা করা হয়।

মূল কাজ : ক্ষতিকারক লিংক বা ইমেইল ব্লক করা এবং ব্যবহারকারীদের সচেতন করা।

vi) অভ্যন্তরীণ হুমকি বা ইনসাইডার থ্রেট (Insider Threat) :

প্রতিষ্ঠানের নিজস্ব কোনো কর্মী যদি ইচ্ছাকৃত বা অনিচ্ছাকৃতভাবে নিরাপত্তার ক্ষতি করে।

মূল কাজ : কর্মীর অ্যাক্সেস প্রিভিলেজ (Privilege) কমানো এবং তার ডিজিটাল কার্যক্রমের ওপর কড়া নজরদারি করা।

***** ২। ইনসিডেন্ট হ্যান্ডলিং প্রক্রিয়া বর্ণনা কর।**

উত্তর : ইনসিডেন্ট হ্যান্ডলিং (Incident Handling) হলো একটি সুশৃঙ্খল প্রক্রিয়া যার মাধ্যমে কোনো প্রতিষ্ঠান সাইবার আক্রমণ বা নিরাপত্তা বিঘ্নিত হওয়ার ঘটনা শনাক্ত করে এবং দ্রুত তার বিরুদ্ধে ব্যবস্থা নেয়।

জনপ্রিয় SANS Institute-এর মতে, এই প্রক্রিয়াটি মূলত 6টি গুরুত্বপূর্ণ ধাপে সম্পন্ন হয়। নিচে ইনসিডেন্ট হ্যান্ডলিং প্রক্রিয়ার ধাপগুলো বিস্তারিতভাবে বর্ণনা করা হলো :

i) প্রস্তুতি (Preparation) : এটি ইনসিডেন্ট হ্যান্ডলিংয়ের সবচেয়ে গুরুত্বপূর্ণ ভিত্তি। কোনো দুর্ঘটনা ঘটার আগেই প্রতিষ্ঠানকে মানসিকভাবে এবং কারিগরিভাবে প্রস্তুত থাকতে হয়।

ইনসিডেন্ট রেসপন্স টিম (IRT) : দক্ষ কর্মীদের নিয়ে একটি দল গঠন করা।

টুলস প্রস্তুত রাখা : ফরেনসিক সফটওয়্যার, নেটওয়ার্ক মনিটরিং টুলস এবং ব্যাকআপ সিস্টেম প্রস্তুত রাখা।

পলিসি ও ট্রেনিং : কর্মীদের নিরাপত্তা সচেতনতা প্রশিক্ষণ দেওয়া।

ii) শনাক্তকরণ (Identification) : এই ধাপে সিস্টেমে কোনো অস্বাভাবিক আচরণ বা নিরাপত্তা লঙ্ঘনের ঘটনা খুঁজে বের করা হয়।

লগ অ্যানালাইসিস : সার্ভার বা ফায়ারওয়াল লগ চেক করা।

অ্যালার্ট মনিটরিং : ইনট্রুশন ডিটেকশন সিস্টেম (IDS) বা অ্যান্টিভাইরাস থেকে আসা সতর্কবার্তা বিশ্লেষণ করা।

ঘটনার পরিধি : আক্রমণটি কতটুকু ছড়িয়েছে এবং কোন কোন ডাটা আক্রান্ত হয়েছে তা নির্ধারণ করা।

iii) নিয়ন্ত্রণ বা কন্টেইনমেন্ট (Containment) : আক্রমণ শনাক্ত করার পর তা যেন পুরো নেটওয়ার্কে বা অন্যান্য ডিভাইসে ছড়িয়ে না পড়ে, সেজন্য আক্রান্ত অংশকে বিচ্ছিন্ন করা হয়। এটি দুই ধরনের হয়

শর্ট-টার্ম কন্টেইনমেন্ট : যেমন-আক্রান্ত কম্পিউটারটিকে ইন্টারনেট থেকে বিচ্ছিন্ন করা ।

লং-টার্ম কন্টেইনমেন্ট : হ্যাকার যে পথে ঢুকেছে সেই পোর্ট বা ব্যাকডোর সাময়িকভাবে বন্ধ করে দেওয়া এবং সিস্টেমের ব্যাকআপ ইমেজ তৈরি করা ।

iv) নির্মূল করা (Eradication) : আক্রমণের বিস্তার থামানোর পর সিস্টেম থেকে ক্ষতিকারক এলিমেন্টগুলো স্থায়ীভাবে মুছে ফেলা হয় ।

ম্যালওয়্যার অপসারণ : সব ধরনের ভাইরাস বা ট্রোজান ডিলিট করা ।

রুট কজ অ্যানালাইসিস : হ্যাকার কীভাবে সিস্টেমে ঢুকেছিল তা খুঁজে বের করা এবং সেই দুর্বলতা (Vulnerability) প্যাচ বা ফিক্স করা ।

অ্যাকাউন্ট আপডেট : হ্যাক হওয়া ইউজার আইডি বা পাসওয়ার্ড পরিবর্তন করা ।

v) পুনরুদ্ধার (Recovery) : এই ধাপে আক্রান্ত সিস্টেমকে পুনরায় স্বাভাবিক কাজের উপযোগী করে তোলা হয় ।

ডেটা রিস্টোর : নিরাপদ ব্যাকআপ থেকে তথ্য পুনরায় লোড করা ।

সিস্টেম টেস্টিং : পুনরায় চালু করার আগে নিশ্চিত করা যে সিস্টেমটি এখন নিরাপদ ।

মনিটরিং : সচল করার পর দীর্ঘ সময় ধরে সিস্টেমটির ওপর কড়া নজর রাখা যাতে পুনরায় আক্রমণ না হয় ।

vi) শিক্ষা গ্রহণ (Lessons Learned) : তদন্তের শেষে পুরো ঘটনার একটি ময়নাতদন্ত বা বিশ্লেষণ করা হয় । এটি ভবিষ্যৎ নিরাপত্তার জন্য অত্যন্ত জরুরি ।

প্রতিবেদন তৈরি : কী ঘটেছিল, কেন ঘটেছিল এবং কীভাবে তা মোকাবিলা করা হলো তার বিস্তারিত রিপোর্ট তৈরি।

ভুল সংশোধন : ইনসিডেন্ট হ্যান্ডলিং প্রক্রিয়ায় কোনো ঘাটতি থাকলে তা সংস্কার করা।

ভবিষ্যৎ পরিকল্পনা : একই ধরনের ঘটনা যেন আর না ঘটে সেজন্য নিরাপত্তা ব্যবস্থাকে আরও আধুনিক করা।

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

**** ১। আইটি অডিট কী?**

উত্তর : একটি প্রতিষ্ঠানের কম্পিউটার সিস্টেম, নেটওয়ার্ক এবং সফটওয়্যারগুলো সঠিকভাবে ও নিরাপদে চলছে কি না, তা একজন বিশেষজ্ঞ (Auditor) দিয়ে পরীক্ষা করানোই হলো আইটি অডিট।

*** ২। আইটি অডিটের মূল লক্ষ্য কী?**

উত্তর : আইটি অডিটের মূল লক্ষ্যসমূহ : সম্পদ সুরক্ষা, তথ্যের অখণ্ডতা বা নির্ভুলতা, সিস্টেমের কার্যকারিতা, সিস্টেমের দক্ষতা, আইন ও নীতিমালার পরিপালন।

***** ৩। স্যাম্পলিং মেথডলোজি(Sampling Methodology) কী?**

উত্তর : স্যাম্পলিং মেথডলোজি হলো একটি পরিসংখ্যানগত প্রক্রিয়া যার মাধ্যমে একটি বিশাল জনগোষ্ঠী বা তথ্যভাণ্ডার থেকে একটি নির্দিষ্ট অংশ বা নমুনা বাছাই করা হয়। এই বাছাইকৃত নমুনার ওপর ভিত্তি করেই পুরো জনগোষ্ঠীর বৈশিষ্ট্য সম্পর্কে একটি ধারণা বা সিদ্ধান্ত নেওয়া হয়।

SOS**সংক্ষিপ্ত প্রশ্নোত্তর :**

* ১। আইটি অডিটিং প্রক্রিয়ার ধাপসমূহ লেখ।

উত্তর : আইটি অডিটিং (IT Auditing) হলো একটি সুশৃঙ্খল প্রক্রিয়া যা ধাপে ধাপে সম্পন্ন করতে হয়। এই প্রক্রিয়াটি নিশ্চিত করে যে একটি প্রতিষ্ঠানের তথ্যপ্রযুক্তি ব্যবস্থা নিরাপদ, দক্ষ এবং নিয়মমাফিক চলছে।

আইটি অডিটিং প্রক্রিয়ার প্রধান ধাপগুলো নিম্নরূপ :

- i) পরিকল্পনা (Audit Planning)
- ii) তথ্য সংগ্রহ ও পর্যবেক্ষণ (Evidence Collection)
- iii) নিয়ন্ত্রণ পরীক্ষা (Testing of Controls)
- iv) বিশ্লেষণ ও মূল্যায়ন (Fieldwork & Analysis)
- v) প্রতিবেদন তৈরি (Reporting)
- vi) ফলো-আপ (Follow-up)

** ২। আইটি অডিট রিপোর্টিং প্রক্রিয়ার ধাপসমূহ আলোচনা কর।

উত্তর : কটি কার্যকর আইটি অডিট রিপোর্টিং প্রক্রিয়া সাধারণত নিচের ধাপগুলোর মাধ্যমে সম্পন্ন হয় :

i) প্রাথমিক পর্যবেক্ষণ বা খসড়া রিপোর্ট তৈরি (Preparation of Draft Report) :

অডিট শেষ করার পর অডিটর প্রথমে একটি খসড়া রিপোর্ট তৈরি করেন। এতে অডিটের উদ্দেশ্য, পরিধি এবং প্রাপ্ত ফলাফলগুলো (Findings)

বিস্তারিতভাবে লেখা থাকে। এটি চূড়ান্ত করার আগে সংশ্লিষ্ট বিভাগের কর্মকর্তাদের সাথে শেয়ার করা হয় যাতে কোনো ভুল বোঝাবুঝি না থাকে।

ii) এক্সিট মিটিং বা আলোচনা (Exit Interview/Meeting) :

খসড়া রিপোর্টটি নিয়ে আইটি ম্যানেজার বা বিভাগীয় প্রধানদের সাথে একটি বৈঠক করা হয়।

উদ্দেশ্য : অডিটর যেসব ত্রুটি পেয়েছেন সেগুলোর সাথে ম্যানেজমেন্ট একমত কি না তা নিশ্চিত করা।

মতামত গ্রহণ : যদি কোনো ত্রুটির পেছনে যৌক্তিক কারণ থাকে, তবে ম্যানেজমেন্ট তা অডিটরকে জানানোর সুযোগ পায়।

iii) ম্যানেজমেন্ট রেসপন্স সংগ্রহ (Gathering Management Responses) :

অডিটর প্রতিটি সমস্যার বিপরীতে ম্যানেজমেন্টের বক্তব্য জানতে চান। ম্যানেজমেন্টকে জানাতে হয় যে তারা সমস্যাটি স্বীকার করছেন কি না। সমস্যা সমাধানের জন্য তারা কী পদক্ষেপ নেবেন। কত দিনের মধ্যে সমস্যাটি সমাধান করা হবে।

iv) চূড়ান্ত রিপোর্ট তৈরি (Final Report Issuance) :

ম্যানেজমেন্টের মতামত যুক্ত করার পর চূড়ান্ত রিপোর্ট তৈরি করা হয়। একটি আদর্শ রিপোর্টে সাধারণত থাকেঃ সারসংক্ষেপ (Executive Summary) : অটেকনিক্যাল ব্যক্তিদের জন্য অডিটের মূল ফলাফল।

অডিট মেথডোলজি : কোন পদ্ধতিতে অডিট করা হয়েছে।

বিস্তারিত ফলাফল : কোথায় কোথায় নিয়ম ভঙ্গ হয়েছে বা দুর্বলতা আছে।

সুপারিশ (Recommendations) : সমস্যা সমাধানে অডিটরের পরামর্শ।

v) অডিট অপিনিয়ন বা রেটিং (Audit Opinion) :

রিপোর্টের শেষে অডিটর তার পেশাদার মতামত দেন।

এটি সাধারণত তিন ধরনের হতে পারে : **Unmodified (সম্পূর্ণ) :** যদি সিস্টেমটি আইন ও নিরাপত্তা অনুযায়ী সঠিক থাকে।

Qualified (শর্তসাপেক্ষ) : কিছু ছোটখাটো ত্রুটি থাকলে।

Adverse (অসন্তোষজনক) : যদি সিস্টেমে বড় ধরনের নিরাপত্তা ঝুঁকি থাকে।

vi) ফলো-আপ এবং ট্র্যাকিং (Follow-up) :

রিপোর্ট প্রদানের কয়েক মাস পর অডিটর পুনরায় চেক করেন যে সুপারিশগুলো বাস্তবায়ন করা হয়েছে কি না। যদি সমস্যাগুলো থেকে যায়, তবে তা পরবর্তী অডিট সাইকেলে অন্তর্ভুক্ত করা হয়।

**** ৩। আইটি অডিট স্যাম্পলিং মেথডলোজির ধাপ ব্যাখ্যা কর।**

উত্তর : নিচে আইটি অডিট স্যাম্পলিং মেথডলোজির প্রধান ধাপগুলো ব্যাখ্যা করা হলো :

i) অডিটের লক্ষ্য নির্ধারণ (Define the Audit Objective) :

স্যাম্পলিং শুরু করার আগে অডিটরকে স্পষ্ট হতে হয় যে তিনি কী পরীক্ষা করতে চান। যেমনঃ "গত এক বছরে অননুমোদিত কেউ সিস্টেমে লগ-ইন

করার চেষ্টা করেছে কি না তা পরীক্ষা করা।" লক্ষ্য স্পষ্ট না হলে সঠিক নমুনা বাছাই করা সম্ভব হয় না।

ii) পপুলেশন বা জনগোষ্ঠী চিহ্নিতকরণ (Define the Population) :

পপুলেশন হলো সেই সম্পূর্ণ ডেটাসেট যেখান থেকে নমুনা নেওয়া হবে। যেমনঃ যদি কোনো ব্যাংকের ক্রেডিট কার্ড ট্রানজেকশন অডিট করতে হয়, তবে পুরো বছরের সব ক্রেডিট কার্ড ট্রানজেকশন হবে 'পপুলেশন'। অডিটরকে নিশ্চিত করতে হয় যে পপুলেশনটি সম্পূর্ণ এবং প্রাসঙ্গিক।

iii) স্যাম্পলিং ইউনিট নির্ধারণ (Define the Sampling Unit) :

পপুলেশনের ভেতরের কোন ছোট অংশটি একটি একক নমুনা হিসেবে গণ্য হবে তা ঠিক করা। এটি হতে পারে একটি নির্দিষ্ট ফাইল, একটি ট্রানজেকশন আইডি, বা একজন ব্যবহারকারীর লগ-ইন রেকর্ড।

iv) স্যাম্পলিং পদ্ধতি নির্বাচন (Selection of Sampling Method) :

অডিটর কোন পদ্ধতিতে নমুনা বাছাই করবেন তা এই ধাপে ঠিক করা হয়। এটি সাধারণত দুই প্রকারের হয় :

স্ট্যাটিস্টিকাল স্যাম্পলিং : এখানে গণিত বা পরিসংখ্যানের সূত্র ব্যবহার করা হয় (যেমন : রেন্ডম স্যাম্পলিং)।

নন-স্ট্যাটিস্টিকাল স্যাম্পলিং : এখানে অডিটর তার নিজের অভিজ্ঞতা ও বিচারবুদ্ধি ব্যবহার করে গুরুত্বপূর্ণ ফাইলগুলো বাছাই করেন (যেমন : জাজমেন্টাল স্যাম্পলিং)।

v) নমুনার আকার নির্ধারণ (Determine the Sample Size) :

অডিটর কতগুলো নমুনা নেবেন তা এই ধাপে ঠিক করা হয়। নমুনার আকার নির্ভর করে ঝুঁকির মাত্রার ওপর। যদি কোনো সিস্টেমে ঝুঁকির সম্ভাবনা বেশি থাকে, তবে নমুনার আকার বড় হতে হয়। আবার সিস্টেম যদি খুব নির্ভরযোগ্য হয়, তবে ছোট নমুনাতেই কাজ চলে।

vi) নমুনা নির্বাচন ও পরীক্ষা (Selecting and Testing the Samples) :

নির্বাচিত পদ্ধতি অনুযায়ী ডাটাবেস বা সিস্টেম থেকে নমুনাগুলো সংগ্রহ করা হয় এবং সেগুলোর ওপর পরীক্ষা চালানো হয়। যেমনঃ 100 টি রেন্ডম লগ ফাইলের মধ্যে দেখা হয় কতগুলো ফাইলে নিরাপত্তা বিধি লঙ্ঘিত হয়েছে।

vii) ফলাফলের মূল্যায়ন (Evaluate the Results) :

নমুনা পরীক্ষা করে যে ত্রুটিগুলো পাওয়া গেল, সেগুলোকে পুরো পপুলেশনের ওপর প্রয়োগ করে দেখা হয়। যেমনঃ 100টি নমুনার মধ্যে যদি ৫টি ভুল থাকে, তবে ধারণা করা হয় পুরো পপুলেশনে ভুলের হার প্রায় 5%।

viii) উপসংহার ও রিপোর্টিং (Conclusion and Reporting) :

প্রাপ্ত ফলাফলের ভিত্তিতে অডিটর তার চূড়ান্ত সিদ্ধান্ত নেন যে সিস্টেমটি অডিটে পাস করেছে নাকি ফেল করেছে। যদি ভুল বা ঝুঁকির হার গ্রহণযোগ্য মাত্রার চেয়ে বেশি হয়, তবে ম্যানেজমেন্টকে দ্রুত ব্যবস্থা নিতে বলা হয়।

SOS**রচনামূলক প্রশ্নোত্তর :**

**** ১।** আইটি অডিটের বিভিন্ন ধরনের বর্ণনা দাও।

উত্তর : আইটি অডিট (IT Audit) হলো একটি প্রতিষ্ঠানের প্রযুক্তিগত অবকাঠামো এবং নিরাপত্তার একটি বিস্তারিত মূল্যায়ন। প্রতিষ্ঠানের কাজের ধরন এবং প্রয়োজনীয়তার ওপর ভিত্তি করে আইটি অডিটকে কয়েকটি প্রধান ভাগে ভাগ করা যায়।

নিচে আইটি অডিটের বিভিন্ন প্রকারভেদ বর্ণনা করা হলো :

i) সিস্টেম এবং অ্যাপ্লিকেশন অডিট (Systems and Applications Audit) :

এই অডিটটি নির্দিষ্ট কোনো সফটওয়্যার বা অ্যাপ্লিকেশনের ওপর করা হয়। অডিটর যাচাই করেন যে- অ্যাপ্লিকেশনটি নির্ভুলভাবে ডেটা প্রসেস করছে কি না। এর মাধ্যমে কোনো ভুল বা জালিয়াতি হওয়ার সুযোগ আছে কি না। ব্যবহারকারীদের অ্যাক্সেস লেভেল (Access Level) ঠিকমতো সেট করা আছে কি না।

ii) তথ্য সুরক্ষা বা সাইবার সিকিউরিটি অডিট (Information Security Audit) :

এটি বর্তমানে সবচেয়ে গুরুত্বপূর্ণ অডিট। এর লক্ষ্য হলো প্রতিষ্ঠানের নেটওয়ার্ক ও ডেটা কতটা নিরাপদ তা যাচাই করা।

ফায়ারওয়াল ও অ্যান্টিভাইরাস : এগুলো আপডেট আছে কি না তা দেখা।

পেনিট্রেশন টেস্টিং : হ্যাকাররা যেভাবে সিস্টেমে ঢোকার চেষ্টা করে, সেভাবে কৃত্রিম আক্রমণ চালিয়ে দুর্বলতা খুঁজে বের করা।

iii) সিস্টেম ডেভেলপমেন্ট অডিট (Systems Development Audit) :

যখন কোনো প্রতিষ্ঠান নতুন কোনো সফটওয়্যার তৈরি করে বা সিস্টেম আপগ্রেড করে, তখন এই অডিট করা হয়। অডিটর দেখেন যে সফটওয়্যার তৈরির প্রতিটি ধাপে সঠিক নিরাপত্তা ও কোডিং স্ট্যান্ডার্ড বজায় রাখা হয়েছে কি না। সিস্টেমটি চালুর আগে পর্যাপ্ত টেস্টিং করা হয়েছে কি না।

iv) আইটি ম্যানেজমেন্ট এবং অবকাঠামো অডিট (IT Management & Infrastructure Audit) :

এই অডিটে আইটি বিভাগের সামগ্রিক পরিচালনা পদ্ধতি পরীক্ষা করা হয়। ডাটা সেন্টারের তাপমাত্রা, বিদ্যুৎ ব্যবস্থা এবং হার্ডওয়্যার রক্ষণাবেক্ষণ ব্যবস্থা দেখা। আইটি কর্মীদের প্রশিক্ষণ এবং তাদের কাজের নিয়মাবলি বা এসওপি (SOP) যাচাই করা।

v) বিজনেস কন্টিনিউটি এবং ডিজাস্টার রিকভারি অডিট (BCP & DR Audit) :

বড় কোনো দুর্ঘটনার পর (যেমন-সার্ভার ধ্বংস হওয়া বা হ্যাকিং) প্রতিষ্ঠান কত দ্রুত আবার সচল হতে পারবে, তা এই অডিটের মাধ্যমে পরীক্ষা করা হয়।

ব্যাকআপ : নিয়মমতো ডেটা ব্যাকআপ রাখা হচ্ছে কি না।

রিকভারি টেস্ট : ব্যাকআপ থেকে ডেটা আসলেই ফিরিয়ে আনা যায় কি না তার ড্রিল বা পরীক্ষা করা।

vi) কমপ্লায়েন্স অডিট (Compliance Audit) :

প্রতিষ্ঠানটি আন্তর্জাতিক বা রাষ্ট্রীয় আইন মেনে চলছে কি না তা এই অডিটে দেখা হয়।

যেমন : ব্যাংকগুলোর জন্য PCI-DSS (ক্রেডিট কার্ড সুরক্ষার নিয়ম) বা স্বাস্থ্য খাতের জন্য HIPAA অডিট। বাংলাদেশে ডিজিটাল নিরাপত্তা আইন মেনে চলা হচ্ছে কি না তাও এর অংশ হতে পারে।

*** ২। অডিটিং ইনফরমেশন সিস্টেমের বর্ণনা দাও। বাকশিবো - ২০২৫

উত্তর : নিচে অডিটিং ইনফরমেশন সিস্টেমের বিস্তারিত বর্ণনা দেওয়া হলোঃ

১. মূল উপাদানসমূহ (Core Components) : অডিটিং ইনফরমেশন সিস্টেম প্রধানত তিনটি বিষয়ের ওপর আলোকপাত করেঃ

প্রযুক্তি (Technology) : হার্ডওয়্যার, নেটওয়ার্ক, ডেটাবেস এবং অপারেটিং সিস্টেমের নিরাপত্তা পরীক্ষা করা।

প্রক্রিয়া (Process) : ডেটা এন্ট্রি থেকে শুরু করে আউটপুট পর্যন্ত প্রতিটি ধাপের কাজের নিয়মাবলি যাচাই করা।

মানুষ (People) : ব্যবহারকারী এবং সিস্টেম অ্যাডমিনিস্ট্রেটরদের ভূমিকা, অনুমতি (Permissions) এবং সচেতনতা পরীক্ষা করা।

২. অডিটিং ইনফরমেশন সিস্টেমের প্রধান লক্ষ্য :

তথ্য সুরক্ষা (Information Security) : হ্যাকিং, ভাইরাস বা অননুমোদিত প্রবেশ থেকে সিস্টেম কতটা নিরাপদ তা নিশ্চিত করা।

তথ্যের নির্ভুলতা (Reliability) : সিস্টেমে থাকা ডেটা যেন সঠিক থাকে এবং কোনো ভুল বা জালিয়াতির মাধ্যমে পরিবর্তিত না হয়।

কার্যকারিতা (Effectiveness) : সিস্টেমটি কি আসলেই প্রতিষ্ঠানের ব্যবসায়িক কাজে সাহায্য করছে, নাকি এটি অকেজো হয়ে পড়ে আছে?

আইনি পরিপালন (Compliance) : সরকারি ডিজিটাল নিরাপত্তা আইন বা আন্তর্জাতিক মানদণ্ড (যেমন- ISO 27001) মেনে চলা হচ্ছে কি না।

৩. অডিটিং ইনফরমেশন সিস্টেমের প্রকারভেদ -এটি মূলত দুই ভাবে করা হয় :

Around the Computer : এখানে কম্পিউটার সিস্টেমের ভেতরে কী ঘটছে তা না দেখে কেবল ইনপুট এবং আউটপুট মিলিয়ে দেখা হয়। এটি সাধারণ হিসাবরক্ষণের মতো।

Through the Computer : এখানে সিস্টেমের ভেতরের সফটওয়্যার লজিক, কোডিং এবং ডেটা প্রসেসিং ধাপগুলো সরাসরি পরীক্ষা করা হয়। এটি আধুনিক এবং অধিক নির্ভরযোগ্য পদ্ধতি।

৪. অডিট প্রক্রিয়া (Audit Process) অডিটিং ইনফরমেশন সিস্টেম সাধারণত নিচের ধাপগুলো অনুসরণ করে :

স্কোপ নির্ধারণ : কোন কোন অ্যাপ্লিকেশন বা নেটওয়ার্ক অডিট করা হবে তা ঠিক করা।

ঝুঁকি মূল্যায়ন : কোন কোন জায়গায় দুর্বলতা থাকতে পারে তা চিহ্নিত করা।

কন্ট্রোল টেস্টিং : পাসওয়ার্ড পলিসি, ফায়ারওয়াল এবং ব্যাকআপ সিস্টেম ঠিকমতো কাজ করছে কি না তা পরীক্ষা করা।

রিপোর্টিং : প্রাপ্ত ত্রুটিগুলো নিয়ে একটি চূড়ান্ত প্রতিবেদন তৈরি করা এবং সমাধানের পরামর্শ দেওয়া।